MINISTRY OF EDUCATION AND TRAINING

FPT UNIVERSITY

Capstone Project Document

Thesis Title:

Evaluating MITRE ATT&CK-Grounded RAG for Technique Attribution from Windows Endpoint Logs: A Replication-and-Extension Study

Group Member	**Student's name:** Hà Hoàng Bách	**Student's ID:** SE196277
Supervisor	**Supervisor's Name:** Hồ Hải	
Capstone Project code	**HOD402 — RAG2ATTCK (Release v1.0.0-rag2attck-study)**	

- Hanoi, October/2026 -

ABSTRACT

Attributing endpoint telemetry to standardized adversary behaviors in the MITRE Adversarial Tactics, Techniques, and Common Knowledge framework is a foundational task in security operations centers and cyber threat intelligence. While modern large language models possess broad parametric knowledge, direct zero-shot prompting without external grounding risks hallucinated technique identifiers, temporal obsolescence, and unverified decisions. Retrieval-Augmented Generation grounds model reasoning in curated external knowledge, yet prior evaluations remain fragmented across unstructured threat reports, cloud or Linux logs, unpinned knowledge bases, and conflated retrieval versus output cutoffs. This study conducts a controlled replication-and-extension evaluation of knowledge-grounded retrieval augmentation for exact technique and sub-technique attribution from Windows endpoint logs under a cryptographically frozen protocol. Our design enforces strict symmetry between an unaugmented baseline and retrieval-augmented conditions across candidate depths of one, three, five, and ten retrieved documents using a fixed reasoning model alias and a dense vector index over 474 active Windows techniques from Enterprise Matrix version 19.2. Across five conditions evaluated over 1,280 synthetic paired test views (6,400 logical inference requests; 6,401 physical attempts), attribution metrics on the 718 mapped, scorable views (excluding 311 ambiguous and 251 unmapped views) show that the unaugmented baseline achieves 77.99 percent end-to-end accuracy and 0.012608 macro-averaged F1 across 474 classes, whereas retrieval augmentation at depth ten achieves 79.53 percent accuracy (an observed difference of plus 1.532 percentage points, nominal 95 percent cluster-bootstrap confidence interval from minus 2.355 to plus 5.300 percentage points, unclustered exact McNemar probability value 0.4219) and 0.014024 macro-averaged F1 (a difference of plus 0.001415, nominal 95 percent cluster-bootstrap confidence interval from plus 0.001011 to plus 0.001792), showing no statistically significant accuracy difference alongside a positive confidence interval on sparse 474-class macro-averaged F1. Independent failure decomposition shows that 80.95 percent of classification errors at depth ten (119 of 147 errors) co-occur with retrieval misses (a 55.29 percent miss rate), where accuracy is 91.28 percent when retrieved versus 70.03 percent when absent, motivating retrieval-focused improvements.

Keywords: MITRE ATT&CK Enterprise v19.2; Retrieval-Augmented Generation (RAG); Large Language Models (LLMs); Windows Endpoint Telemetry; Sysmon Event Logs; Threat Technique Attribution; Security Operations Center (SOC); Dense Vector Retrieval (FAISS); Replication-and-Extension Study; Reproducible Cybersecurity Evaluation.

ACKNOWLEDGEMENT

First and foremost, I would like to express my sincere gratitude to the Board of Rectors and the Faculty of Information Assurance at **FPT University** for establishing a rigorous academic environment and providing the foundational knowledge in network security, incident response, and security project management required to undertake this research thesis in course **HOD402**.

I extend my deepest appreciation to my Supervisor, **Mr. Hồ Hải**, for his dedicated guidance, critical methodological feedback, and unwavering insistence on scientific rigor throughout the eight-week research cycle. His emphasis on controlled experimental design, anti-label-leakage verification, and honest reporting of statistical uncertainty shaped the core architecture of the **RAG2ATT&CK** study.

Finally, I would like to thank the members of the Capstone Project Evaluation Committee for their time, insightful review, and constructive assessment of this thesis, as well as my family and peers at FPT University for their continuous encouragement and support.

TABLE OF CONTENTS

ABSTRACT 2

ACKNOWLEDGEMENT 3

LIST OF FIGURES 6

LIST OF TABLES 7

ABBREVIATIONS 8

CHAPTER 1 INTRODUCTION 10

1.1. Background 10

1.2. Problem Statement 11

1.3. Research Objectives 11

1.4. Significance of the Study 13

1.5. Scope and Limitations 14

1.6. Thesis Structure 15

CHAPTER 2 LITERATURE REVIEW 17

2.1. Review of Previous Studies 17

2.2. Summary of the Literature Review 19

2.3. Research Contributions 22

CHAPTER 3 METHODOLOGY 24

3.1. Research Design 24

3.2. Data Collection Methods 27

3.3. Sampling and Data Analysis Techniques 28

3.4. Limitations of the Methodology 30

CHAPTER 4 EXPERIMENTS AND RESULTS 31

4.1. Introduction 31

4.2. Presentation of Data 31

4.3. Analysis of Results 37

4.4. Interpretation of Results 40

4.5. Comparison with Literature 44

4.6. Implications of the Results 44

CHAPTER 5 DISCUSSION 46
5.1. Research Objectives Revisited 46
5.2. Summary of Key Findings 46
CHAPTER 6 CONCLUSION AND FUTURE WORK 49
6.1. Conclusion 49
6.2. Future Work 49
REFERENCES 51
APPENDICES 53

LIST OF FIGURES

• Figure 1. Dual-View Attribution Architecture (CTI Log -> all-MiniLM-L6-v2 -> FAISS -> gpt-5.6-luna xhigh) — Chapter 3, Section 3.1 24

• Figure 2. Attribution Accuracy vs. Candidate Depth k across Conditions (N=718 Scorable Views with 95% Bootstrap CI) — Chapter 4, Section 4.2..... 32

• Figure 3. 474-Class Macro-F1 Performance across Retrieval Depths (8 Active Supported Classes vs. 466 Zero-Support Universe Classes) — Chapter 4, Section 4.2 32

• Figure 4. Standalone Retrieval Hit@k vs. Multi-Label Macro Recall@k across Depths k=1, 3, 5, 10 on 718 Scorable TEST Views — Chapter 4, Section 4.2..... 34

• Figure 5. Post-Retrieval Stratum Accuracy: P(Correct | Hit) vs. P(Correct | Miss) across Retrieval Depths — Chapter 4, Section 4.2 34

• Figure 6. Request Inference Latency Scaling: Mean and Median Duration (ms) across Conditions (P95 Withheld per Protocol) — Chapter 4, Section 4.2 35

• Figure 7. Conservative Ledger Spend vs. Token-Usage Cost (USD) and Aggregate Input Token Volume — Chapter 4, Section 4.2 36

• Figure 8. Decoupled Independent Failure Decomposition and Co-occurrence Breakdown at Retrieval Depth k=10 — Chapter 4, Section 4.2 36

LIST OF TABLES

- Table 1. Canonical Research Questions, Hypotheses, Experimental Variables, and Evaluation Metrics — Chapter 1, Section 1.3 13
- Table 2. Multi-Dimensional Comparator Matrix Grounded in Primary Evidence (Part 1: Comparators 1–4) — Chapter 2, Section 2.2 19
- Table 3. Multi-Dimensional Comparator Matrix Grounded in Primary Evidence (Part 2: Comparators 5–8 and RAG2ATT&CK) — Chapter 2, Section 2.2 20
- Table 4. Primary Attribution Performance, 474-Class Macro-F1 Bootstrap CIs, and Ground-Truth Complexity — Chapter 4, Section 4.2 31
- Table 5. Attribution Diagnostic Metrics Across Experimental Conditions — Chapter 4, Section 4.2 32
- Table 6. Representation Stratification: Single-Event vs. Contextual-Event Views — Chapter 4, Section 4.2 33
- Table 7. Paired Scorable Representation Concordance and Unclustered McNemar Discordance (N=278 complete pairs) — Chapter 4, Section 4.2 33
- Table 8. Decoupled Failure Decomposition Matrix Across Independent Diagnostic Axes (D2i) — Chapter 4, Section 4.2 33
- Table 9. Resource Consumption, Latency Scaling, Token-Usage Cost, and Conservative Ledger Spend — Chapter 4, Section 4.2 35
- Table 10. Whole-Study Financial Ledger and Budget Reconciliation — Chapter 4, Section 4.2 37
- Table 11. Cryptographic Reproducibility Manifest — Appendix A 53
- Table 12. Supplementary Execution Provenance (Canonical Run Mode) — Appendix A ... 53
- Table 13. Eight-Week Capstone Implementation Roadmap: Planned Window vs. Actual Execution Timestamps — Appendix B 55
- Table 14. Risk Register, Severity Assessment, and Reproducibility Mitigation Controls — Appendix B 56

ABBREVIATIONS

Summary of Domain Abbreviations and Technical Acronyms in RAG2ATT&CK.

Acronym	Full Meaning & Technical Context in RAG2ATT&CK
AI / ML / NLP	Artificial Intelligence / Machine Learning / Natural Language Processing
APT	Advanced Persistent Threat
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge (MITRE Enterprise Matrix v19.2)
BM25	Best Matching 25 (Lexical bag-of-words retrieval ranking function)
CI	Confidence Interval (95% Cluster Bootstrap over 440 scenario clusters) / Continuous Integration
CP / HOD402 / OJT	Capstone Project / Course HOD402 / On-the-Job Training (FPT University)
CTI	Cyber Threat Intelligence
DEV / TEST	Development Split (30 pairs / 60 views) / Canonical Test Split (640 pairs / 1,280 views; 718 scorable)
eBPF	Extended Berkeley Packet Filter (Linux kernel telemetry comparator)
EDR / SIEM	Endpoint Detection and Response / Security Information and Event Management
FAISS	Facebook AI Similarity Search (`IndexFlatIP` exact inner-product vector index)
FN / FP / TP	False Negative / False Positive / True Positive
FWER	Family-Wise Error Rate
GT	Ground Truth (`single-GT` = 1 technique; `multi-GT` = multiple concurrent techniques)
Hit@k / Recall@k	Sample-Level Any-Hit Rate (Hit@k, `ANY_GT_RETRIEVED`) vs. Fractional Multi-Label Macro Recall@k
HR / MAP / MRR / NDCG	Hit Rate / Mean Average Precision / Mean Reciprocal Rank / Normalized Discounted Cumulative Gain
IA / IDS	Information Assurance / Intrusion Detection System
JSON / XML	JavaScript Object Notation / Extensible Markup Language
KB	Knowledge Base (474 active Windows ATT&CK techniques & sub-techniques)
LADE	LLM-Assisted Advanced Persistent Threat Detection and Explanation (Gwak et al., 2026/2027)
LLM	Large Language Model (Fixed OpenAI `gpt-5.6-luna` alias with `reasoning_effort=xhigh`)
LOLBin	Living-Off-The-Land Binary (e.g., `certutil.exe`, `wevtutil.exe`, `schtasks.exe`)
MMR	Maximal Marginal Relevance
OMML / SDT	Office Math Markup Language / Structured Document Tag (OpenXML)
RAG	Retrieval-Augmented Generation

Acronym	Full Meaning & Technical Context in RAG2ATT&CK
RQ	Research Question (RQ1: Efficacy; RQ2: Retrieval & Failure Axes; RQ3: Depth/Cost/Latency)
SHA-256	Secure Hash Algorithm 256-bit cryptographic digest
SOC	Security Operations Center
STIX	Structured Threat Information Expression (JSON schema for MITRE ATT&CK v19.2)
Sysmon	Microsoft Windows System Monitor (Event IDs 1, 3, 7, 12, 13, etc.)
TTP	Tactics, Techniques, and Procedures

CHAPTER 1
INTRODUCTION

1.1. Background

> **Canonical Study Provenance & Scope Binding:** Bound to `canonical-metric-bundle-v2` (SHA-256: `442b5933858caafc9da3c06ee9398637213ed30d7a7db80195c0babb1195ef34`), Terminal Run Seal `ae7a9ada86927a79e0c6916b44d3f0ba9e1f9756df55dd7b2fce712b35d48701` (`run_id=live-66b94b1676bf46a9`), Protocol `experiment-protocol-v1.1` (`d3bf3d31...`), and Official Release `v1.0.0-rag2attck-study` (`ca8d39824a72e80053371e208506bfdc6332dc5d`). All empirical claims are strictly bounded to the `synthetic-paired-v1` benchmark; generalization to production enterprise telemetry remains unproven.

Enterprise defense relies heavily on the ingestion, processing, and interpretation of host endpoint telemetry. System instrumentation tools—such as Microsoft Sysmon and native Windows Security Event Auditing—record granular operating system activity, including process creation (`Event ID 1` / `4688`), network connections (`Event ID 3`), image loading (`Event ID 7`), registry modifications (`Event IDs 12/13`), service installations (`Event ID 4697`), user account management (`Event ID 4720`), and event log clearing (`Event ID 1102`). Security Operations Center (SOC) analysts and incident response teams continuously triage these log streams to detect malicious behavior and perform *threat attribution*: mapping discrete host observables to standardized adversary Tactics, Techniques, and Procedures (TTPs) defined in the MITRE ATT&CK framework [1].

Accurate ATT&CK mapping enables automated playbooks, contextualized threat hunting, kill-chain reconstruction, and cross-organization cyber threat intelligence (CTI) sharing. However, manual attribution at the exact sub-technique level (`Txxxx.yyy`) is labor-intensive and cognitively demanding. An adversary executing a living-off-the-land binary (LOLBin) like `certutil.exe` might be staging tools from an external server (Ingress Tool Transfer: `T1105`) or decoding payloads locally (Deobfuscate/Decode Files or Information: `T1140`). Disambiguating these nuanced attacker goals requires deep domain knowledge, familiarity with command-line syntax, and comprehensive command of the evolving ATT&CK taxonomy.

Originally initiated from the broad capstone theme *"AI Assistant for Classifying and Mapping Attack Techniques According to the MITRE ATT&CK Framework from System Logs"* (*Trợ lý AI phân loại và ánh xạ kỹ thuật tấn công theo khung MITRE ATT&CK từ log hệ thống*), systematic literature screening revealed that while foundation reasoning models [2, 3] and Retrieval-Augmented Generation (RAG) [4] have been widely applied to unstructured CTI report annotation [5, 6], controlled evaluations on endpoint telemetry remain scarce. Consequently, this thesis was formally refined into **RAG2ATT&CK**: a controlled conceptual replication-and-extension empirical study that isolates the exact effect of MITRE ATT&CK-grounded RAG [4] on Windows endpoint log technique attribution under a cryptographically frozen scientific protocol.

1.2. Problem Statement

Commercial foundation models with extended internal reasoning capabilities (such as OpenAI's `gpt-5.6-luna` [2, 3]) provide native structured output enforcement and multi-step reasoning over dense technical context. Nevertheless, relying solely on an unaugmented LLM's internal parametric memory (`No-RAG`) or deploying naive retrieval pipelines introduces four critical scientific and operational problems:

1. **Parametric Hallucination, Invalid Identifiers, and Knowledge Obsolescence:** Without external grounding, LLMs may synthesize non-existent technique identifiers (such as `T1543.006`, which is absent from the Enterprise ATT&CK taxonomy) or confuse platform scopes by assigning non-Windows techniques (such as Cloud API: `T1059.009`, an active cloud technique in ATT&CK v19.2 inapplicable to Windows hosts). Furthermore, static model weights cannot reflect quarterly ATT&CK updates, revocations, or deprecations, and lack auditable citations back to official procedure descriptions.
2. **Lexical and Representation Gap Between Raw Endpoint Telemetry and ATT&CK Prose:** Prior ATT&CK RAG systems (such as TechniqueRAG [5] and H-TechniqueRAG [6]) operate on human-written CTI reports that share rich natural-language vocabulary with MITRE ATT&CK descriptions. In contrast, Windows endpoint telemetry consists of structured, terse execution fields (`CommandLine`, `ParentImage`, `TargetObject`, `ServiceFileName`, and Windows Security Event XML attributes such as `TargetUserName`, `SubjectUserName`, and `SubjectLogonId`), creating a severe semantic representation gap for standard dense bi-encoder retrievers.
3. **Methodological Fragmentation and Conflation of Retriever Depth (k):** Prior telemetry studies either focus on binary process-tree behavior detection without exact sub-technique IDs (Yang & Hsu [7]), omit RAG entirely during command-log interpretation (CAM-LDS [8]), provide bibliographic-only Sysmon mappings without verified retrieval controls (Okuma et al. [9]), evaluate non-Windows environments without ablating retriever depth (AWS CloudTrail RAG [10], Linux eBPF Trace2ATT&CK [11]), or conflate the length of the model's emitted candidate list (`Top-k` output cutoff) with the depth of the external retrieval engine (k) (LADE [12]).
4. **Entangled Upstream Retrieval Misses vs. Downstream Generation Errors:** Existing end-to-end evaluations rarely decouple upstream retrieval misses ($Y_i \cap R_{i,k} = \emptyset$) from downstream LLM selection discrepancies ($Y_i \cap R_{i,k} \neq \emptyset \wedge \hat{y}_i \notin Y_i$), leaving security engineers unable to determine how classification errors co-occur across the vector index versus the reasoning model.

1.3. Research Objectives

The primary objective of this study is to execute a strictly controlled, reproducible empirical evaluation comparing unaugmented zero-shot reasoning (**No-RAG**) against MITRE ATT&CK-grounded **RAG** across systematic retrieval depths ($k \in \{1, 3, 5, 10\}$) for exact Windows technique

attribution. Specifically, the research is governed by three canonical Research Questions (**RQ1–RQ3**) and corresponding hypotheses (**H1–H3**):

- **RQ1 (Retrieval-Augmented Attribution Efficacy):** Does grounding a reasoning LLM (`gpt-5.6-luna`, `reasoning_effort=xhigh`) in retrieved MITRE ATT&CK v19.2 enterprise reference context improve exact technique and sub-technique attribution accuracy and 474-class Macro-F1 over a strictly matched No-RAG baseline under identical reasoning settings?
- **RQ2 (Retrieval Quality and Failure Axes):** When attribution errors occur under RAG, how do upstream retrieval misses ($Y_i \cap R_{i,k} = \emptyset$) and downstream model selection discrepancies ($Y_i \cap R_{i,k} \neq \emptyset \wedge \hat{y}_i \notin Y_i$) manifest across independent measurement axes with overlaps? Furthermore, how do single-event versus multi-event contextual representations correlate with standalone Hit@k, multi-label Macro Recall@k, and downstream accuracy?
- **RQ3 (Retrieval Depth, API Cost, and Latency Trade-Offs):** How does varying retrieval candidate depth ($k \in \{1, 3, 5, 10\}$) affect attribution performance, context distractor susceptibility, wall-clock inference latency, token-usage cost, and conservative ledger spend under a hard USD 19.99 financial guard?

Table 1: Canonical Research Questions, Hypotheses, Experimental Variables, and Evaluation Metrics.

RQ	Research Question	Hypothesis	Independent Variable	Dependent Variable	Conditions	Primary & Diagnostic Metrics
RQ1	Does grounding a reasoning LLM in retrieved MITRE ATT&CK enterprise reference context improve exact technique and sub-technique attribution accuracy and 474-class Macro-F1 over an unaugmented No-RAG baseline under symmetric reasoning settings?	H1: Macro-F1(RAG) > Macro-F1(No-RAG) and Acc_{e2e}(RAG) > Acc_{e2e}(No-RAG)	Presence of retrieved ATT&CK context (No-RAG vs. RAG)	Exact ATT&CK Technique / Sub-technique attribution quality	`no_rag`, `rag_k1`, `rag_k3`, `rag_k5`, `rag_k10`	Headline Accuracy (Acc_{e2e}), Valid Accuracy (Acc_{valid}), 474-class Macro-F1, 95% Cluster-Bootstrap CI (440 clusters), Unclustered McNemar p
RQ2	When attribution errors occur under RAG, how do upstream retrieval misses ($Y_i \cap R_{i,k} = \emptyset$) and downstream model selection discrepancies ($Y_i \cap R_{i,k} \neq \emptyset \wedge \hat{y}_i \notin Y_i$) manifest across independent measurement axes with overlaps, and how do single-event vs. contextual-event views correlate with these axes?	H2: Downstream prediction correctness is higher in the post-retrieval stratum where at least one ground-truth technique is retrieved ($P(\text{Correct} \mid Y_i \cap R_{i,k} \neq \emptyset) > P(\text{Correct} \mid Y_i \cap R_{i,k} = \emptyset)$)	Ground-truth intersection with Top-k candidates ($Y_i \cap R_{i,k}$) & telemetry view type	Conditional prediction correctness & error locus co-occurrence	`rag_k1`, `rag_k3`, `rag_k5`, `rag_k10` (278 single vs. 440 contextual TEST views)	Standalone Hit@k (`ANY_GT_RETRIEVED`), Multi-label Macro Recall@k, $P(\text{Correct} \mid Y_i \cap R_{i,k} \neq \emptyset)$, $P(\text{Correct} \mid Y_i \cap R_{i,k} = \emptyset)$, D2i Axes
RQ3	How does varying retrieval candidate depth ($k \in \{1, 3, 5, 10\}$) affect attribution performance, distractor susceptibility, wall-clock latency, and API token/ledger costs?	H3: Very small k ($k=1$) risks distractor susceptibility when retrieval misses, while larger k increases prompt token volume, latency, and cost	Retrieval candidate depth $k \in \{0, 1, 3, 5, 10\}$	Accuracy, Macro-F1, input/output token volume, latency, usage cost, and conservative ledger spend	6,400 canonical dispatches across 5 conditions ($1{,}280 \times 5$)	Total & Mean Input/Output Tokens, Mean & Median Latency (s), Token-Usage Cost (USD), Conservative Ledger Spend (USD) under USD 19.99 cap

1.4. Significance of the Study

To maintain strict scientific integrity, **RAG2ATT&CK does not claim global novelty** for applying RAG to MITRE ATT&CK [5, 6], analyzing Windows Sysmon logs with LLMs [7, 8, 9], comparing RAG against a No-RAG baseline [10, 11], or evaluating Top-k trade-offs in isolation [6]. Instead, the significance of this thesis lies in its **controlled conceptual replication-and-extension design** that unites six rigorous experimental controls never simultaneously enforced in prior literature:

1. Symmetric Controlled Contrast: Comparing No-RAG and RAG using the identical requested model alias (`gpt-5.6-luna`), identical reasoning settings (`reasoning_effort=xhigh`,

`max_output_tokens=8192`), and a byte-identical prompt template (`prompts/baseline_v1.txt`), isolating retrieved context as the sole treatment variable.

2. **Pinned ATT&CK Enterprise Matrix v19.2:** Binding all retrieval and scoring operations to an immutable STIX snapshot of 474 active Windows techniques and sub-techniques, eliminating taxonomy drift.
3. **Independent Failure Measurement Axes (Protocol D2i):** Decoupling upstream retrieval misses from downstream LLM selection discrepancies without forced mutually exclusive partitioning, while distinguishing sample-level Hit@k from fractional multi-label Macro Recall@k.
4. **Systematic Retriever Depth Ablation ($k \in \{1, 3, 5, 10\}$):** Strictly separating external retriever depth *k* from single-ID output prediction (`{"technique_id": "..."}`).
5. **Paired Single-Event vs. Contextual-Event Evaluation:** Testing how multi-event telemetry windows correlate with dense retrieval ranks and downstream attribution across 640 paired TEST scenarios (278 complete scorable positive pairs).
6. **Zero-Cost Offline Reproducibility (`OFFLINE_GUARD`):** Providing a cryptographically sealed verification archive (`public_v4_candidate_20261003.zip`) that enables any independent auditor to replay all 6,400 predictions, bootstrap confidence intervals, and financial ledgers offline at USD 0.00 API cost.

1.5. Scope and Limitations

The scope of this thesis is strictly governed by Scientific Protocol `experiment-protocol-v1.1` (`config/experiment_protocol_v1.json`, SHA-256 `a402b04a...`) and the Scope Alignment Addendum (Section 15 of the Research Plan):

- **Target Taxonomy & Positive Technique Scope:** The retrieval corpus and Macro-F1 evaluation universe encompass all **474 active Windows techniques and sub-techniques** (176 root, 298 sub-techniques) in MITRE ATT&CK Enterprise v19.2. Positive ground-truth support in the benchmark is concentrated across **8 high-frequency Windows techniques**: `T1059.001` (PowerShell), `T1059.003` (Windows Command Shell), `T1053.005` (Scheduled Task), `T1543.003` (Windows Service), `T1136.001` (Local Account), `T1547.001` (Registry Run Keys / Startup Folder), `T1685.005` (Clear Windows Event Logs), and `T1105` (Ingress Tool Transfer).
- **Benchmark Dataset Scope (`synthetic-paired-v1`):** The dataset comprises **670 scenario pairs (1,340 views** across 1,434 unique events), split into **640 TEST pairs (1,280 views)** across 52 template families and **30 DEV pairs (60 views)** across 12 template families with zero family overlap. Across the 1,280 TEST views, authoritative ground-truth joining yields **718 scorable mapped-positive views** (278 single-event, 440 contextual-event; 678 single-GT, 40 multi-GT across 440 scenario clusters), while 311 ambiguous views and 251 unmapped negative views are excluded from headline accuracy per Protocol Decisions D2c and D2b.

- **Explicit Non-Goals:** This study does not train or fine-tune model weights, does not build multi-agent workflows, does not deploy production SIEM/Wazuh/EDR infrastructure, and does not construct knowledge graphs.

> **CRITICAL DISCIPLINARY CLAIM BOUNDARY & Forensic Telemetry Blocker (Task 2 / T15):** All experimental evaluations and conclusions in this thesis are strictly bounded to the `synthetic-paired-v1` benchmark and do NOT evaluate real-world enterprise telemetry. While the initial research plan contemplated evaluating public Windows-APT telemetry (Mendeley v3, Mozaffari et al., 2026 [13]), an internal forensic audit conducted during Task 2 (`reports/final_repair_validation.md`) uncovered **15,713 unresolved cell discrepancies** between individual scenario CSVs and the combined dataset (14,930 cells in `_source.id` and 509 cells in binary event data suffering numeric precision truncation, `#NAME?` formula corruption in `param3`, and divergent timestamps). This triggered a formal fail-closed stop (`RECONCILIATION_DIVERGENT`). Under Protocol Decision D6 (`NOT_REQUIRED_FOR_SYNTHETIC_BENCHMARK`), Task T15 is formally recorded as `Deferred / Out-of-Scope` (`DATA_UNAVAILABLE`), and generalization to real production telemetry remains unproven.

1.6. Thesis Structure

The remainder of this Capstone Project Thesis Document is organized into six chapters, followed by References and Appendices, strictly adhering to the FPT University Information Assurance Research Thesis structure:

- **Chapter 1 (Introduction):** Establishes the operational background of Windows endpoint threat attribution, states the research problem, formulates Research Questions RQ1–RQ3 (Table 1), defines the study's significance, and declares the strict synthetic scope boundary.
- **Chapter 2 (Literature Review):** Presents a source-bounded audit of eight core comparator studies (6/8 full-text verified, 2/8 metadata-only), synthesizes the 16-dimension comparator matrix (Tables 2 & 3), and defines the research gap and contributions.
- **Chapter 3 (Methodology):** Details the dual-view system architecture (Figure 1), Frozen Scientific Protocol v1.1 (D1–D7), `gpt-5.6-luna` inference configuration and provenance policy, symmetric prompt template, FAISS `IndexFlatIP` retrieval engine, `synthetic-paired-v1` data engineering, `INFERENCE_ALLOWLIST` anti-leakage controls, and formal mathematical evaluation definitions (Hit@k vs. Recall@k, piecewise D2j Macro-F1, cluster bootstrap vs. unclustered McNemar).
- **Chapter 4 (Experiments and Results):** Reports the complete empirical results from the 6,400-request canonical campaign (Tables 4–10, Figures 2–8), analyzes RQ1–RQ3 (including both Accuracy and Macro-F1 CIs, TEST-only vs. combined TEST+DEV retrieval cohorts, and a verbatim multi-view worked example), compares findings with prior literature, and outlines SOC engineering implications.
- **Chapter 5 (Discussion):** Revisits the research objectives, synthesizes key empirical takeaways, examines synthetic data boundaries, operational latency/cost trade-offs, runtime

infrastructure resilience, and evaluates Threats to Validity across Internal, Statistical, External, and Construct dimensions.

- **Chapter 6 (Conclusion and Future Work):** Summarizes the thesis conclusions across RQ1–RQ3, certifies open-science reproducibility, and proposes concrete future research hypotheses in hybrid lexical-dense retrieval, event pre-filtering, and verified real-world telemetry benchmarking.

CHAPTER 2
LITERATURE REVIEW

2.1. Review of Previous Studies

To situate RAG2ATT&CK within contemporary cybersecurity and natural language processing scholarship, we conducted a rigorous, source-bounded literature audit of eight primary comparator studies alongside foundational works on Retrieval-Augmented Generation [4], the MITRE ATT&CK framework [1], and Windows APT datasets [13]. In strict adherence to scholarly truthfulness (`reports/T33_related_work.md`, PR #8 commit `6783f209`, and `reports/evidence/t33_lade_claim_verification_record.json`), we explicitly disclose the verification tier of each comparator:

- **Full-Text Content Audited (6/8 Comparators):** Lekssays et al. (*TechniqueRAG*, ACL 2025) [5], Morbiato et al. (*H-TechniqueRAG*, 2026) [6], Landauer et al. (*CAM-LDS*, IJIS 2026) [8], Adediran et al. (*CloudTrail RAG*, CMC 2026) [10], Lupinacci et al. (*Trace2ATT&CK*, 2026) [11], and Gwak et al. (*LADE*, SecureComm 2026/2027, 28-page author manuscript PDF verified against SHA-256 `6e8384569254bc4cf82dd4d0191746907ff40fa76016275946651cf47d6f4985`) [12].
- **Partial / Metadata-Only / Access-Blocked (2/8 Comparators):** Yang & Hsu (SITAIBA/Springer 2026) [7] is verified solely from the publisher abstract and bibliographic metadata due to subscription paywall restrictions; Okuma et al. (IEEE ICSPIS 2023) [9] is verified solely from the IEEE bibliographic record. All claims concerning these two works are strictly bounded to verified metadata (`UNVERIFIED`).

Stream 1: Retrieval-Augmented Generation for Unstructured CTI Text Annotation

TechniqueRAG (Lekssays et al., 2025) [5] introduced a retrieval-and-reranking pipeline for annotating unstructured Cyber Threat Intelligence (CTI) text reports with exact MITRE ATT&CK techniques and sub-techniques (`Txxxx.yyy`). The system retrieves a candidate pool of K=40 annotated text-label exemplars from TRAM and MITRE procedure corpora using BM25, reranks them via DeepSeek-v3 to select a fixed k=3 exemplars, and feeds them to a fine-tuned Ministral-8B generator. While TechniqueRAG analyzes retriever versus generator errors, it operates exclusively on natural-language CTI prose rather than host logs and does not report standalone retriever Hit@k across varying depths. **H-TechniqueRAG (Morbiato et al., 2026) [6]** extended CTI annotation using a hierarchical dense RAG architecture (FAISS IVF) with Llama-3-8B-Instruct over 1,200 CTI-RCM, 2,800 MITRE, and 450 TRAM samples. It routes queries from tactics to techniques, evaluating sensitivity to tactic count M (peaking at M=3 with per-tactic quota K_A=15) against a zero-shot Llama 3 baseline, and highlights context distraction when excessive candidates are injected. However, H-TechniqueRAG evaluates human-authored CTI prose rather than structured endpoint telemetry and does not perform a flat retriever depth sweep $k \in \{1, 3, 5, 10\}$.

Stream 2: Windows Sysmon and Host Command Telemetry Mapping to MITRE ATT&CK

Okuma et al. (2023) [9] established an early foundation for automated mapping of Windows Sysmon event logs to ATT&CK techniques using Atomic Red Team executions; however, as only the IEEE bibliographic record was accessible during our audit, its internal mapping mechanism remains marked `UNVERIFIED`. **Yang & Hsu (2026) [7]** represent the closest input-level comparator on Windows: their system integrates Windows Sysmon process trees, semantic matching RAG, and in-context analysis across Mistral-7B, phi-2, and TinyLlama-1.1B with a matched No-RAG baseline. Crucially, however, based on verified abstract metadata, Yang & Hsu focus on binary malicious behavior detection and natural-language explanation (reporting Precision, F1, and False Positive Rate) rather than exact 474-class ATT&CK technique/sub-technique ID attribution. **LADE (Gwak et al., 2026/2027) [12]** evaluates chronological host command and script traces for APT detection and ranked ATT&CK technique mapping (`Top-3` and `Top-10` output cutoffs) across `gpt-oss-120B`, `Llama-3.3-70B`, `Mistral-Small-3.2-24B`, and `Gemini-2.5-Pro`. Full-text verification of the 28-page manuscript (`LADE-2026.pdf`, pp. 13–15) confirms that LADE evaluates two benchmarks: the **AVIATOR dataset** (35 attack and 32 benign sequences) and a **Caldera-derived dataset** comprising two sets of 33 APT sequences for 2:1 and 10:1 benign-to-APT ratio settings (each set of 33 APT sequences consists of 20 adversary-profile sequences and 13 MITRE emulation-plan sequences—specifically 5 lateral-movement and 8 multi-stage attack sequences—paired with 33 benign sequences). To handle long traces (Section 4.1, pp. 7–8), LADE segments traces at **70% of each model's context window** (all Caldera sequences fit in a single window; on AVIATOR, segmentation is triggered for 12 sequences on Mistral-Small-3.2-24B, 10 sequences each on gpt-oss-120B and Llama-3.3-70B under 128k windows [≈ 89,600 token limit], and 6 sequences on Gemini-2.5-Pro under a 1M window). Across 5 voting runs (p. 15), 76.3% of sequences achieve 5–0 unanimity, 13.8% achieve 4–1 consensus, and 10% split 3–2. Importantly, LADE uses rubric prompting with static ATT&CK text and performs **no RAG retrieval ablation**.

Stream 3: RAG-Assisted Telemetry Attribution in Cloud and Linux Environments

Adediran et al. (2026) [10] provide the closest experimental-design comparator for controlled No-RAG versus RAG contrast on security telemetry, evaluating Gemini 2.5 Pro across 200 AWS CloudTrail JSON events (122 malicious, 78 benign) using a two-step query-expansion RAG pipeline on Vertex AI. While they demonstrate that RAG improves accuracy, precision, recall, and F1 over unaugmented Gemini 2.5 Pro, their study operates on cloud API logs rather than Windows endpoint telemetry, omits numeric retrieval depth k, does not report standalone retriever Hit@k or Recall@k, and contains an unresolved internal reporting discrepancy in its published text (stating in Section 2 and the conclusion that retrieval-generation gaps account for 60% of errors, while the Section 6.4.1 heading reports 26%). **Trace2ATT&CK (Lupinacci et al., 2026) [11]** maps 347 Linux Atomic Red Team kernel executions (represented as eBPF provenance graphs) to ATT&CK techniques using Chroma dense retrieval (800-word ATT&CK chunks with Maximal Marginal Relevance) across six models (`foundation-sec-8b`, `qwen3.5-9b`, `gpt-oss`, `gemma4-31b-it`,

`deepseek-r1-qwen32b`, `llama3.3-70b`), comparing against a prompting baseline. However, Trace2ATT&CK fixes both retriever depth and output cutoff at 5 chunks/candidates, preventing separation of standalone retriever recall from downstream generation accuracy.

Stream 4: Zero-Shot Multi-Source Log Interpretation and Anti-Leakage Methodology

CAM-LDS (Landauer et al., 2026) [8] evaluates zero-shot LLM log interpretation across 7 multi-step cyber attack scenarios (198 log steps across 18 Linux `auditd`/`syslog` and IDS sources) using frontier models (`GPT-5.5`, `GPT-5.2`, `Llama 4`, `Qwen 3`, `Ministral` per §5.1). CAM-LDS introduces rigorous anti-label-leakage sanitization—stripping explicit ATT&CK labels and detector rule names before prompting—and evaluates output candidate ranking (`P@k`, `Recall@k`, `MRR`) while collapsing sub-techniques to parent techniques (`Txxxx`, §5.2.2). However, CAM-LDS deliberately excludes RAG.

2.2. Summary of the Literature Review

Table 2 and Table 3 synthesize our 16-dimension comparative evaluation across all eight comparator works and RAG2ATT&CK. To ensure full legibility within the 6.50-inch printable page width, Table 2 presents Comparators 1–4 and Table 3 presents Comparators 5–8 alongside RAG2ATT&CK.

Table 2: Multi-Dimensional Comparator Matrix Grounded in Primary Evidence (Part 1: Comparators 1–4).

Dimension	Yang & Hsu (2026) [7]	Adediran et al. (2026) [10]	CAM-LDS (Landauer et al., 2026) [8]	TechniqueRAG (Lekssays et al., 2025) [5]
1. Primary Input	Windows Sysmon process trees	AWS CloudTrail JSON events	Linux system logs (auditd, syslog) + IDS alerts	Unstructured CTI text reports
2. Target Platform	Windows	AWS Cloud	Linux / Multi-source	Cross-platform (CTI text)
3. Core Task	Malicious behavior detection & explanation	Cloud threat detection & ATT&CK mapping	Benchmark log interpretation	CTI technique & sub-technique annotation
4. ATT&CK Target Granularity	Behavior explanation (Exact ID UNVERIFIED)	Technique & Sub-technique (`Txxxx.yyy`)	Collapses sub-techniques to parent (`Txxxx`); §5.2.2 parent-technique eval	Technique & Sub-technique (`Txxxx.yyy`)
5. RAG Architecture	Semantic matching RAG	Two-step query expansion RAG (Vertex AI)	None (Zero-shot prompting)	Exemplar retrieval (BM25 + DeepSeek v3 rerank)
6. Retrieval Corpus	UNVERIFIED	ATT&CK Cloud, AWS catalogue, threat blogs	N/A	Annotated text-label pairs (TRAM, Procedures)
7. Matched No-RAG Baseline?	Yes (Mistral, phi-2, TinyLlama w/o RAG)	Yes (Gemini 2.5 Pro baseline w/o RAG)	Evaluates only zero-shot (no RAG)	Yes (Zero-shot and fine-tuned w/o RAG)

Dimension	Yang & Hsu (2026) [7]	Adediran et al. (2026) [10]	CAM-LDS (Landauer et al., 2026) [8]	TechniqueRAG (Lekssays et al., 2025) [5]
8. Top-k Retrieval Ablation?	UNVERIFIED (full text unavailable)	No (Numeric k NOT REPORTED; ablation deferred)	Evaluates output cutoff Top-k (§5.2.2); no retriever	Evaluates pool size K=40, fixed set of k=3 exemplars
9. Standalone Retriever Metrics?	UNVERIFIED	NOT REPORTED (Generation gap only)	N/A	P/R/F1 on ranking; standalone Hit@k NOT REPORTED
10. Failure Decomposition?	UNVERIFIED	Qualitative error categories (unresolved 26% vs 60% discrepancy)*	No	Analyzes generator vs retriever errors
11. Telemetry Leakage Controls	UNVERIFIED	Notes `stratus-red-team` agent in raw logs	Strips explicit ATT&CK labels/tactics	CTI text; no detector rule metadata
12. Primary Models	Mistral-7B, phi-2, TinyLlama-1.1B	Gemini 2.5 Pro	GPT-5.5, GPT-5.2, Llama 4, Qwen 3, Ministral (Journal)	Ministral-8B (fine-tuned)
13. Headline Metrics	Precision, F1, False Positive Rate	Accuracy, Precision, Recall, F1, Latency, Cost	Technique Rank, P@k, Recall@k, MRR	Precision, Recall, Macro-F1, Micro-F1
14. Primary Dataset	Attack samples + benign process trees	200 AWS CloudTrail events (122 mal / 78 ben)	7 scenarios, 198 log steps, 18 sources	TRAM, Procedures, Expert CTI datasets
15. Closest Similarity	Sysmon logs + matched No-RAG/RAG	Controlled No-RAG vs RAG on telemetry	Exact technique prediction from command logs	ATT&CK RAG with retrieval quality analysis
16. Key Difference	Binary detection; process tree heuristics	AWS CloudTrail API; two-step Vertex RAG	Zero-shot only (no RAG); Linux focus	Unstructured CTI text; fine-tunes generator

Table 3: Multi-Dimensional Comparator Matrix Grounded in Primary Evidence (Part 2: Comparators 5–8 and RAG2ATT&CK).

Dimension	H-TechniqueRAG (Morbiato et al., 2026) [6]	Trace2ATT&CK (Lupinacci et al., 2026) [11]	Okuma et al. (2023) [9]	LADE (Gwak et al., 2026/2027) [12]	RAG2ATT&CK (This Work)
1. Primary Input	Unstructured CTI text reports	Linux eBPF provenance graphs	Windows Sysmon event logs	Chronological command/script traces	Windows endpoint telemetry (Sysmon / Security logs)
2. Target Platform	Cross-platform (CTI text)	Linux	Windows	Cross-platform host OS	Windows Enterprise
3. Core Task	CTI technique annotation & context routing	Kernel telemetry to ATT&CK mapping	UNVERIFIED (bibliographic record only)	APT detection & TTP mapping	Exact ATT&CK Technique / Sub-technique attribution

Dimension	H-TechniqueRAG (Morbiato et al., 2026) [6]	Trace2ATT&CK (Lupinacci et al., 2026) [11]	Okuma et al. (2023) [9]	LADE (Gwak et al., 2026/2027) [12]	RAG2ATT&CK (This Work)
4. ATT&CK Target Granularity	Tactic → Technique hierarchy	Ranked Technique & Sub-technique candidates	UNVERIFIED	Ranked Technique candidates (Top-3/10)	Exact Technique & Sub-technique (`Txxxx.yyy`)
5. RAG Architecture	Hierarchical dense RAG (FAISS IVF)	Dense chunk retrieval (Chroma + MMR)	UNVERIFIED	None (Rubric prompting with static ATT&CK text)	Dense semantic RAG (FAISS IndexFlatIP cosine)
6. Retrieval Corpus	ATT&CK Enterprise (CTI-RCM, TRAM, MITRE)	ATT&CK Enterprise KB (800-word chunks)	UNVERIFIED	N/A	Official ATT&CK Enterprise v19.2 (474 active Windows docs)
7. Matched No-RAG Baseline?	Yes (Zero-shot Llama 3 direct-prompt baseline)	Yes (Prompting baseline w/o RAG)	UNVERIFIED (full text access blocked)	Prompting only (no RAG ablation)	Yes (Strictly matched gpt-5.6-luna alias w/o RAG)
8. Top-k Retrieval Ablation?	Tactic count M sensitivity (peak M=3, quota K_A=15); not flat k sweep	Fixed retriever depth (5 chunks), output cutoff 5	UNVERIFIED	Output candidate cutoff k ∈ {3, 10}; no RAG retriever	Yes (k ∈ {1, 3, 5, 10} systematically ablated)
9. Standalone Retriever Metrics?	Micro P/R/F1, MAP@10; standalone Hit@k NOT REPORTED	NOT REPORTED (Fixed 5 chunks; standalone Recall@k not separable)	UNVERIFIED	N/A	Yes (Both Hit@k and Macro Recall@k reported)
10. Failure Decomposition?	Analyzes distractor impact in flat vs hierarchical	No (End-to-end system evaluation)	UNVERIFIED	No	Independent axes with overlaps (D2i)
11. Telemetry Leakage Controls	CTI text; curated benchmarks	Kernel syscalls; no detector rule metadata	UNVERIFIED (full text access blocked)	Script command lines analyzed	Strict field allowlist; detector rules/labels purged
12. Primary Models	Llama-3-8B-Instruct	foundation-sec-8b, qwen3.5-9b, gpt-oss, gemma4-31b-it, deepseek-r1-qwen32b, llama3.3-70b	NOT REPORTED / UNVERIFIED	gpt-oss-120B, Llama-3.3-70B, Mistral-Small-3.2-24B, Gemini-2.5-Pro	OpenAI gpt-5.6-luna (xhigh reasoning effort)
13. Headline Metrics	Micro P/R/F1, MAP@10, Latency, API calls	HR@5, MRR@5, NDCG@5	NOT REPORTED / UNVERIFIED	Precision, Recall, F1, HR/MRR/NDCG @ 3, 10	End-to-End Accuracy, 474-class Macro-F1, Hit@k, Recall@k
14. Primary Dataset	1,200 CTI-RCM + 2,800 MITRE + 450 TRAM	347 Linux Atomic Red Team executions	Atomic Red Team Sysmon logs (metadata only)	AVIATOR (35/32 seqs) & Caldera-derived (33 APT seqs per 2:1 & 10:1 setting + 33 benign)	1,280 paired synthetic TEST views (640 scenario pairs)

Dimension	H-TechniqueRAG (Morbiato et al., 2026) [6]	Trace2ATT&CK (Lupinacci et al., 2026) [11]	Okuma et al. (2023) [9]	LADE (Gwak et al., 2026/2027) [12]	RAG2ATT&CK (This Work)
15. Closest Similarity	Investigating retrieval depth & distractor noise	Telemetry-to-ATT&CK mapping comparing RAG/prompt	Windows Sysmon mapped to ATT&CK	Host command execution traces mapped to ATT&CK	Integrates telemetry, exact attribution, depth ablation
16. Key Difference	Unstructured CTI text; hierarchical routing	Linux eBPF provenance graphs; no depth ablation	UNVERIFIED (IEEE record only; full text inaccessible)	Prompting only (no RAG); AVIATOR & Caldera sequence evaluation	Windows endpoint logs + exact ID + depth ablation + error split

**Note on Adediran et al. [10]: The published primary text contains an unresolved internal discrepancy without authorial resolution, stating in Section 2 and the conclusion that retrieval-generation gaps account for 60% of errors, while Section 6.4.1 heading reports 26%. We refrain from imputing derived fractions to the authors.*

Research Gap Synthesis: Although prior studies have investigated LLM-based ATT&CK mapping [8, 12], RAG-assisted Sysmon or security-log analysis [7], ATT&CK-grounded RAG in cloud [10] and Linux kernel telemetry [11], and retrieval/reranking for CTI text annotation [5, 6], **controlled evaluations of MITRE ATT&CK-grounded RAG for exact technique and sub-technique attribution (`Txxxx.yyy`) from Windows endpoint telemetry remain limited**. Crucially, no single prior work combines Windows endpoint telemetry, a strictly symmetric same-LLM No-RAG versus RAG contrast, systematic retriever depth ablation ($k \in \{1, 3, 5, 10\}$) decoupled from single-ID output prediction, and independent measurement of upstream retrieval misses versus downstream LLM selection discrepancies.

2.3. Research Contributions

Positioned as a **conceptual replication-and-extension empirical study**, this thesis makes four concrete scientific and engineering contributions:

1. **Controlled Empirical Replication on Windows Endpoint Telemetry:** We replicate the core treatment contrast of Adediran et al. [10] (`No-RAG` vs. `ATT&CK-Grounded RAG`) while transferring the domain from AWS CloudTrail to Windows Sysmon and Security Event telemetry [7, 9], holding the requested `gpt-5.6-luna` alias (`reasoning_effort=xhigh`, `max_output_tokens=8192`), output schema, and `prompts/baseline_v1.txt` strictly constant across 6,400 dispatches.
2. **Diagnostic Extension Decoupling Retrieval vs. Generation Error Axes:** Extending the retrieval-quality analysis of TechniqueRAG [5] and H-TechniqueRAG [6] to terse endpoint logs, we report both standalone sample-level hit rate (Hit@1 = 3.76%, Hit@10 = 44.71%) and fractional multi-label recall (Macro Recall@1 = 2.95%, Macro Recall@10 = 42.80%) on the 718 scorable TEST views, alongside post-retrieval stratum accuracy (91.28% when at least one ground-truth technique is retrieved vs. 70.03% when absent), showing that 80.95% (119/147) of classification errors at k=10 co-occur with retrieval misses.

3. **Observational Characterization of Per-Technique Retrieval Misses and Multi-Event Rank Shifts:** Across the 718 scorable TEST cohort (with auxiliary combined TEST+DEV diagnostics from Task T20 explicitly delineated), we document: (a) a 0.00% Hit@10 rate on `T1136.001` (`0/95` TEST views—comprising `70` views containing Security `EventID=4720` [`10` single-event `{4720}` views and `60` contextual views across EventID set combinations `{4688, 4720}` (`38`), `{1, 4720}` (`12`), and `{13, 4720}` (`10`)] where sanitized `EventID=4720` records retain the 6 allowlisted fields `TimeCreated`, `Computer`, `EventID`, `TargetUserName`, `SubjectUserName`, `SubjectLogonId`, plus `25` single-event process-creation views [`13` `EventID=4688` and `12` Sysmon `EventID=1`]; `0/99` in combined TEST+DEV) alongside a 16.67% Hit@10 rate on `T1105` (`18/108` on TEST; `15.79%`, `18/114` on TEST+DEV); and (b) multi-event retrieval rank shifts under the Top-10-censored rank comparison (`comparison_rank = rank if found else 11`), where contextual views exhibit a worse anchor-technique rank in **21.58% (`60/278`)** of complete scorable TEST pairs, a better rank in **7.55% (`21/278`)**, and a tied rank in **70.86% (`197/278`: `58` tied at a finite Top-10 rank and `139` absent from Top-10 in both views)** (`21.96%`, `65/296` worse vs. `7.77%`, `23/296` better and `70.27%`, `208/296` tied [`61` finite + `147` absent-both] in the combined TEST+DEV T20 cohort). These patterns are consistent with hypotheses involving lexical mismatch, competing retrieved techniques, and context dilution; the present observational diagnostics do not isolate these mechanisms causally.
4. **Cryptographically Sealed Benchmark and Forensic Data Governance:** Following our Task 2 forensic discovery of 15,713 cell discrepancies in public Windows-APT CSV exports [13], we deliver the byte-audited `synthetic-paired-v1` benchmark (`INFERENCE_ALLOWLIST` leakage-scrubbed) and an offline reproduction suite (`public_v4_candidate_20261003.zip`) verified across 178/178 automated audit gates.

CHAPTER 3
METHODOLOGY

3.1. Research Design

Our experimental methodology is structured as a controlled, five-condition comparative evaluation governed by the cryptographically frozen protocol `experiment-protocol-v1.1` (Canonical Decisions Digest: `d3bf3d31ad307100ac437a7daecc470bf12de9ada49f19de3d77592d5a21974c`; Protocol Config File SHA-256: `a402b04ab463172f9d4079bff27b089ca8a21ffd0805d097af6cb1f3c7b5a8fb`), approved under reference `RAG2ATTCK-PROTOCOL-V1.1-FROZEN`. Figure 1 illustrates the dual-view attribution architecture comparing the unaugmented `No-RAG` baseline against the `RAG` pipeline.

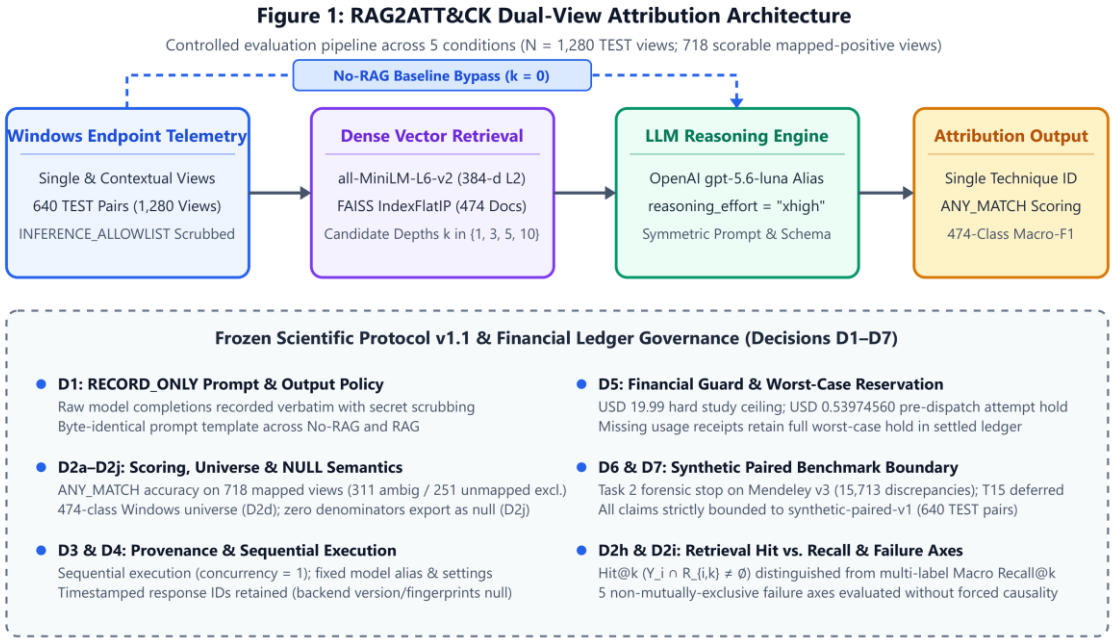


Figure 1: Dual-View Attribution Architecture (CTI Log -> all-MiniLM-L6-v2 -> FAISS -> gpt-5.6-luna xhigh).

1. Frozen Scientific Protocol Policies (D1–D7 and D2a–D2j)

- **D1 (Raw Response Policy: `RECORD_ONLY`):** The raw textual completion emitted by the LLM is captured inline (`raw_response: str`) within prediction records for full auditability, with fail-closed secret sanitization.
- **D2a (Multi-Label Ground Truth Semantics: `ANY_MATCH`):** For samples with multi-label ground truth (Y_i), a single predicted technique $\hat{y}_i$ is scored as correct if $\hat{y}_i \in Y_i$.
- **D2b & D2c (Empty and Ambiguous Ground Truth: `EXCLUDE`):** Negative/unmapped samples (`label_status == "unmapped"`, N=251) and ambiguous samples (`label_status == "ambiguous"`, N=311) are excluded from headline accuracy and Macro-F1, but retained in diagnostic and financial accounting.

- **D2d (Macro-F1 Universe: `FROZEN_BENCHMARK_UNIVERSE`):** Macro-averaging is computed over the entire fixed 474-technique active Windows universe ($|C|=474$), ensuring constant denominators across all conditions.
- **D2e & D2f (Invalid ID & Provider/Parser Failure Accounting: `INCLUDE_IN_DENOMINATOR`):** Hallucinated/non-existent ATT&CK IDs, provider timeouts, HTTP errors, and JSON parse failures are retained in all headline accuracy denominators and scored as incorrect (Fail-Closed).
- **D2g (Retired ATT&CK IDs: `ALLOW_HISTORICAL`):** Predictions matching deprecated or revoked STIX IDs are tracked distinctly without silent remapping.
- **D2h (Retrieval Success Definition: `ANY_GT_RETRIEVED`):** Sample-level retrieval hit (Hit@k) is satisfied if $Y_i \cap R_{i,k} \neq \emptyset$, whereas fractional multi-label coverage is tracked separately via Macro Recall@k.
- **D2i (Failure Decomposition: `INDEPENDENT_AXES`):** Errors are analyzed along five independent diagnostic axes without forced artificial precedence.
- **D2j (Zero Denominator Convention: `NULL`):** Undefined per-class metric fractions evaluate strictly to `null` in JSON exports while contributing 0.0 to the 474-class macro-average numerator.
- **D3–D7 (Execution & Governance Controls):** Timestamped model response ID binding (`D3: ALLOW_LATEST_WITH_TIMESTAMP_BINDING`), strictly sequential execution `concurrency = 1` (`D4`), hard worst-case attempt budget reservation (`D5`), independence from blocked external telemetry (`D6`), and full 1,280-view `PAIRED_TEST` execution (`D7`).

2. Language Model Configuration, Provenance Policy, and Symmetric Prompting

The language model configuration is frozen in `config/model.json` (SHA-256: `312c34ce...`): OpenAI `gpt-5.6-luna` invoked via the OpenAI Responses API (`client.responses.create`) with identical reasoning settings (`reasoning_effort="xhigh"` and `max_output_tokens=8192`, a unified ceiling covering internal reasoning and visible output tokens; note that fixed reasoning settings do not constrain the model to expend identical actual reasoning tokens per query). In accordance with Protocol Decision D3 (`ALLOW_LATEST_WITH_TIMESTAMP_BINDING`) and `artifacts/results/outputs/run_provenance.json` (SHA-256: `90918c9e...`), the requested model alias and inference configuration were fixed across all conditions and timestamped response IDs (`has_response_ids: true`, `has_timestamps: true`) were retained for every dispatch; however, the recorded provenance does not identify an immutable backend model snapshot or system fingerprint (`model_version: null`, `system_fingerprints: []`). Sampling parameters (`temperature`, `top_p`, `seed`) are left unconfigured at uniform provider defaults across all conditions, with deterministic exponential backoff retry resilience (`max_retries=3`, initial delay 1.0s, factor 2.0, max delay 30.0s, socket timeout 120s).

Crucially, native JSON Schema enforcement (`strict: true`) targets the Pydantic `TechniquePrediction` schema (`{"technique_id": "..."}`) while deliberately omitting regex

pattern constraints at the API schema layer. This architectural separation enables a **two-layer post-hoc taxonomic validation pipeline**: (1) *Layer 1 (Canonical Syntax Check)* validates strings against `^T\d{4}(?:\.\d{3})?$`, classifying malformed strings (e.g., `"T1059.1"`) as `INVALID_ID` rather than `MALFORMED_RESPONSE`; (2) *Layer 2 (Registry Membership Check)* validates syntax-compliant IDs against the pinned ATT&CK v19.2 registry. Both `no_rag` and all `rag_k*` conditions share the byte-identical prompt template `prompts/baseline_v1.txt` (SHA-256: `b751fde1ee33b03ec0bdc07cbba10267002d2086cf22b91a74bdfd123856f206`):

```
You are an expert cyber threat intelligence and SOC analyst.
Analyze the following endpoint evidence and determine the single most specific and
accurate MITRE ATT&CK Technique or Sub-technique ID.

If reference context is provided below, use it as supporting information for the
attribution. If no reference context is provided, perform the attribution using the
endpoint evidence alone.

ENDPOINT EVIDENCE:
{ENDPOINT_EVIDENCE}

---
REFERENCE CONTEXT:
{RETRIEVED_CONTEXT}
---

Respond with a single JSON object containing only the "technique_id" field. Do not
include markdown formatting, code fences, or explanatory text.
```

3. Dense Retrieval Subsystem, Prefix Consistency, and Financial Guard

Frozen in `config/retrieval.json` (SHA-256: `b33a9391...`), the dense retriever encodes both ATT&CK corpus documents and sanitized telemetry queries into 384-dimensional unit L2-normalized vectors ($\|v\|_2 = 1.0$) using `sentence-transformers/all-MiniLM-L6-v2` (pinned to Hugging Face commit `1110a243fdf4706b3f48f1d95db1a4f5529b4d41`) indexed in a FAISS `IndexFlatIP` structure. Under unit L2 normalization, inner product equals cosine similarity:

$$\langle \hat{q}, \hat{d}_i \rangle = \frac{q \cdot d_i}{\|q\|_2 \|d_i\|_2} = \cos(q, d_i)$$

To guarantee deterministic tie-breaking and strict prefix consistency across retrieval depths $k \in \{1, 3, 5, 10\}$, the retriever scores all $N=474$ documents, sorts via compound key $\text{sort}_{\text{k}}\text{ey} = (\text{-score}, \text{technique}_{\text{i}}\text{d})$, and slices the top k, satisfying the **Prefix Consistency Invariant**:

$$\forall k_1 < k_2 \in \{1,3,5,10\}:\ \text{results}(k_1) \equiv \text{results}(k_2)[:k_1]$$

Under Protocol Decision D5 and `config/pricing_v1.json` (short-context $\leq$ 272k tokens: input `$0.20/M`, cache-read `$0.02/M`, cache-write `$0.25/M`, output `$1.20/M`), the runner places a worst-case reservation of **USD 0.53974560** before each attempt under a hard cap of $\text{Cap} = 1{,}280 \times 5 \times 4 = 25{,}600$ attempts and an authorized study budget ceiling of **USD 19.99000000**.

3.2. Data Collection Methods

Data collection and corpus engineering in RAG2ATT&CK encompass three cryptographically audited pipelines: (1) MITRE ATT&CK v19.2 Windows knowledge base extraction, (2) forensic auditing of external public telemetry, and (3) generation and leakage-scrubbing of the `synthetic-paired-v1` benchmark.

- **MITRE ATT&CK Enterprise Matrix v19.2 Corpus Census:** Starting from the official raw STIX bundle `enterprise-attack-19.2.json` (published 05 August 2026; SHA-256: `dc1639caa5501d720e280cf1cbd8fbe009884a0c9b3e6e9ed9d0c25166c3d8f4`), we parse exactly **858** `attack-pattern` objects. Removing **161 unique inactive** objects (**149 revoked** with `revoked: true` and **12 deprecated** with `x_mitre_deprecated: true`, zero overlap: 149 + 12 = 161) yields **697 active enterprise techniques**. Filtering for `"Windows" in x_mitre_platforms` yields the canonical active Windows corpus of **474 techniques and sub-techniques** (**176 root techniques** [37.1%] and **298 sub-techniques** [62.9%]), verified to have 0 orphan sub-techniques and serialized in `attack/corpus/enterprise-windows-v19.2.jsonl` (SHA-256: `b2193411...`).
- **Synthetic Paired Benchmark (`synthetic-paired-v1`):** Following the Task 2 forensic rejection of Mendeley v3 CSVs (15,713 cell discrepancies), we engineered `synthetic-paired-v1` (`data/ground_truth/synthetic/dataset_manifest.json`, SHA-256: `4576b793...`), comprising **670 scenario pairs** (**1,340 evaluation views** across 1,434 unique events). The **TEST split** contains **640 scenario pairs (1,280 views = 640 single-event + 640 contextual-event)** across 52 template families; the **DEV split** contains **30 scenario pairs (60 views)** across 12 template families, with strict family disjointness ($\text{Family}_{\text{TEST}} \cap \text{Family}_{\text{DEV}} = \emptyset$). In each pair, the *single-event view* presents the isolated anchor event, while the *contextual-event view* embeds the anchor event within a sequence of 2–3 correlated host events.
- **Strict Field Whitelisting and Anti-Leakage Controls (`INFERENCE_ALLOWLIST` and `CANONICAL_TELEMETRY_SCHEMA` in `src/synthetic.py`):** All inference payloads (`data/ground_truth/synthetic/inference.jsonl`, SHA-256: `90d5f59e...`) are projected through `INFERENCE_ALLOWLIST = {"sample_id", "endpoint_evidence"}`, where each event dictionary inside the JSON-serialized `endpoint_evidence` list retains only the sanitized per-channel behavioral fields defined in `CANONICAL_TELEMETRY_SCHEMA` (note that provider/channel names do not appear as keys inside `endpoint_evidence`): `UtcTime`, `Computer`, `EventID`, `Image`, `CommandLine`, `ParentImage`, `ParentCommandLine`, `User`, `ProcessId`, `ParentProcessId`, `ProcessGuid`, `ParentProcessGuid`, `LogonGuid`, `LogonId`, `Hashes` (Sysmon ProcessCreate `EventID 1`); `UtcTime`, `Computer`, `EventID`, `Image`, `User`, `SourceIp`, `SourcePort`, `DestinationIp`, `DestinationPort`, `Protocol`, `ProcessId`, `ProcessGuid` (Sysmon NetworkConnect `EventID 3`); `UtcTime`, `Computer`, `EventID`, `Image`, `TargetFilename`, `ProcessId`, `ProcessGuid`, `User` (Sysmon FileCreate `EventID 11`); `UtcTime`, `Computer`, `EventID`, `Image`, `EventType`, `TargetObject`, `Details`, `ProcessId`, `ProcessGuid`, `User` (Sysmon Registry `EventID 13`); `TimeCreated`, `Computer`, `EventID`, `NewProcessName`,

`CommandLine`, `ParentProcessName`, `SubjectUserName`, `TargetUserName`, `NewProcessId`, `ProcessId`, `SubjectLogonId` (Security ProcessCreate `EventID 4688`); `TimeCreated`, `Computer`, `EventID`, `ServiceName`, `ServiceFileName`, `ServiceType`, `ServiceStartType`, `ServiceAccount`, `SubjectUserName`, `SubjectDomainName`, `SubjectLogonId` (Security ServiceInstall `EventID 4697`); `TimeCreated`, `Computer`, `EventID`, `TaskName`, `TaskContent`, `SubjectUserName`, `SubjectLogonId` (Security ScheduledTask `EventID 4698`); the 6 allowlisted fields `TimeCreated`, `Computer`, `EventID`, `TargetUserName`, `SubjectUserName`, `SubjectLogonId` (Security AccountCreated `EventID 4720`, i.e., 3 metadata fields + 3 account-identifier fields); and the 5 allowlisted fields `TimeCreated`, `Computer`, `EventID`, `SubjectUserName`, `SubjectLogonId` (Security AuditLogCleared `EventID 1102`). Notice that Active Directory attribute names such as `SamAccountName` and `UserPrincipalName` have zero occurrences in `inference.jsonl`. All Sigma/Wazuh rule titles, `rule.mitre.*` tags, scenario identifiers, and synthetic lexical markers (such as `Contoso`) are completely purged and verified by `tests/test_benchmark_inputs.py` and `tests/test_synthetic_freeze.py`.

3.3. Sampling and Data Analysis Techniques

Authoritative Join and Scorable Cohort Census: Joining the 1,280 TEST views (`split_manifest.json` → `views.jsonl`) against `ground_truth.jsonl` yields **718 mapped positive scorable views** (comprising **678 single-GT views** and **40 multi-GT views**; stratified by representation into **278 Single-Event Views** and **440 Contextual-Event Views**, 278 + 440 = 718). Across the 640 TEST scenario pairs, **278 complete scorable pairs** have valid positive ground truth on *both* single and contextual views (278 × 2 = 556 views), **162 pairs** have valid ground truth on *only* the contextual view (162 × 1 = 162 views; single view unmapped/ambiguous), and **200 pairs** have valid ground truth on *neither* view (556 + 162 = 718 scorable views across 278 + 162 = 440 valid pair clusters). The remaining **311 ambiguous views** (261 single, 50 contextual) and **251 unmapped negative views** (101 single, 150 contextual) are excluded from headline accuracy per Protocol Decisions D2c and D2b. Ground-truth support across the 718 scorable TEST views is concentrated across the **8 benchmark techniques** totaling **768 annotations**: `T1053.005` (85), `T1059.001` (107), `T1059.003` (107), `T1105` (108), `T1136.001` (95), `T1543.003` (108), `T1547.001` (98), and `T1685.005` (60).

Formal Mathematical Evaluation Metrics: Under `ANY_MATCH` semantics (D2a), for sample i with ground-truth set $Y_i \subseteq C$ ($|C| = 474$) and model prediction $\hat{y}_i$, the correctness indicator, Headline End-to-End Accuracy (Acc_{e2e}, D2f), and Valid Output Accuracy (Acc_{valid}) are defined as:

$$I_{\text{correct}}(i) = 1 \text{ if } \hat{y}_i \in Y_i, \quad 0 \text{ otherwise}$$

$$\text{Acc}_{\text{e2e}} = \frac{1}{N_{\text{scorable}}} \sum_{i=1}^{N_{\text{scorable}}} I_{\text{correct}}(i), \quad \text{Acc}_{\text{valid}} = \frac{1}{N_{\text{valid}}} \sum_{i \in \text{Valid}} I_{\text{correct}}(i)$$

Standalone Retrieval Metrics (Hit@k vs. Sample-Averaged Multi-Label Macro Recall@k): Because the scorable TEST cohort includes 40 multi-label (`mapped_multi`) views ($|Y_i| > 1$),

sample-level binary hit rate (Hit@k per Decision D2h `ANY_GT_RETRIEVED`) and sample-averaged multi-label fractional recall (termed `macro_recall` / Macro Recall@k in project artifacts) are mathematically distinct and are reported separately. Given ground-truth label set Y_i and top-k retrieved candidate set $R_{i,k}$:

$$\text{Hit@}k = \frac{1}{N}\sum_{i=1}^{N} 1\{Y_i \cap R_{i,k} \neq \emptyset\}, \quad \text{Macro Recall@}k = \frac{1}{N}\sum_{i=1}^{N} \frac{|Y_i \cap R_{i,k}|}{|Y_i|}$$

For example, if a view has two ground-truth techniques ($|Y_i|=2$) and the retriever places exactly one of them in $R_{i,k}$, that view contributes 1.0 to Hit@k but 0.5 to sample-averaged Macro Recall@k.

474-Class Macro-F1 and Piecewise D2j `NULL` Semantics: For each class $c \in C$, `compute_condition_metrics` in `src/evaluation/experiment_metrics.py` and the canonical bundle analysis pipeline `scripts/analysis/evaluate_rqs.py` track TP_c, FP_c, FN_c, support $support_c = TP_c + FN_c$, and predictions $pred_c = TP_c + FP_c$. Per Decision D2j, undefined per-class ratios export as JSON `null` (`None` in Python) across three boundary cases: **Case A (Unobserved: $support_c=0 \wedge pred_c=0$)** exports `precision=null, recall=null, f1=null`; **Case B (Unpredicted: $support_c>0 \wedge pred_c=0$)** exports `precision=null, recall=0.0, f1=0.0`; **Case C (Hallucinated False Positive: $support_c=0 \wedge pred_c>0$)** exports `precision=0.0, recall=null, f1=0.0`; and **Case D ($TP_c=0$ with $support_c>0 \wedge pred_c>0$)** yields $P_c=0.0$, $R_c=0.0$, $F1_c=0.0$. Rather than dividing by $P_c + R_c$ when either quantity is `null` or zero, the effective per-class score $F1_c^*$ accumulated in the 474-class macro-average is defined directly in terms of counts:

$$F1_c^* = \frac{2 \cdot TP_c}{2 \cdot TP_c + FP_c + FN_c} \text{ if } TP_c > 0, \qquad 0 \text{ if } TP_c = 0, \quad \text{Macro-F1} = \frac{1}{474}\sum_{c \in C} F1_c^*$$

Statistical Inference & Independent Failure Axes (D2i): Uncertainty bounds on both accuracy differences ΔAcc = Acc(RAG) - Acc(No-RAG) and Macro-F1 differences ΔMacro-F1 = Macro-F1(RAG) - Macro-F1(No-RAG) are estimated as nominal, unadjusted 95% confidence intervals (`NO_MULTIPLE_COMPARISON_CORRECTION_PRE_SPECIFIED_PRIMARY_CONTRASTS`) via **1,000 cluster-bootstrap resamples** (`seed=42`) over the **440 scenario pair clusters** (`cluster_unit: pair_id`, preserving within-pair dependence between single and contextual views of the same scenario while treating between-pair independence across template-derived synthetic pairs as a modeling assumption). Alongside cluster-bootstrap CIs, we report **exact two-sided binomial McNemar tests** over discordant view pairs (b, c) at N=718 (and N=278 for complete representation pairs); we explicitly note that exact McNemar treats view-level discordant pairs as independent trials without cluster adjustment, so cluster-bootstrap CIs serve as the primary cluster-aware inference reference. Failure analysis tracks five non-mutually-exclusive axes (`retrieval_miss`, `provider_failure`, `parse_failure`, `invalid_attack_id`, `valid_but_wrong_classification`) and compares post-retrieval subsets P(Correct | $Y_i \cap R_{i,k} \neq \emptyset$) and P(Correct | $Y_i \cap R_{i,k} = \emptyset$).

3.4. Limitations of the Methodology

Four methodological limitations and epistemic boundaries are formally enforced in this study:

1. **Synthetic Benchmark Regularities:** While `synthetic-paired-v1` guarantees verified ground truth and zero label leakage, template-derived command lines and 2–3 event contextual windows cannot capture the full background noise, obfuscation, or scale of production enterprise SOC streams.
2. **Sparse Class Support Across the 474-Class Ontology (Support-Based vs. With-Hallucination Ceiling):** Because positive ground truth in TEST is concentrated in 8 active techniques while 466 classes have zero support ($F1_c^* = 0$), unweighted 474-class Macro-F1 has a support-based upper bound of $8 / 474 \approx 0.01688$ (1.69%), and false-positive predictions landing on any of the 466 zero-support classes (Case C) further penalize the active classes' recall without ever increasing the 8-class numerator sum. We preserve the 474-class denominator without post-hoc subset rescaling to honor Protocol D2d.
3. **Epistemic Boundaries of Failure Decomposition and Post-Retrieval Stratification:** Under Protocol D2i, co-occurrence of classification errors with `retrieval_miss` ($Y_i \cap R_{i,k} = \emptyset$) is an observational diagnostic association, not an interventional proof that replacing the retriever alone would eliminate all co-occurring errors. Likewise, the difference between $P(\text{Correct} \mid Y_i \cap R_{i,k} \neq \emptyset)$ (91.28% at k=10) and $P(\text{Correct} \mid Y_i \cap R_{i,k} = \emptyset)$ (70.03%) compares two post-retrieval sample strata partitioned by retriever outcome (which correlates with intrinsic log lexical clarity) rather than a randomized intervention on identical samples.
4. **Observational Nature of Representation Contrasts:** Comparisons between Single-Event (N=278) and Contextual-Event (N=440) cohorts—and across the 40 label-divergent multi-stage pairs within the 278 complete pairs—represent observational associations confounded by multi-stage scenario label expansion rather than isolated causal effects.

CHAPTER 4
EXPERIMENTS AND RESULTS

4.1. Introduction

This chapter presents the complete empirical results obtained from the canonical live experimental campaign (`experiment_id="synthetic-paired-test-1"`, `run_id="live-66b94b1676bf46a9"`) executed under `experiment-protocol-v1.1` at execution commit `80dbeb3fe2316e5d2d39de2ed6a5a2d15cfa9315` and bound to `canonical_metric_bundle_v2.json` (SHA-256: `442b5933858caafc9da3c06ee9398637213ed30d7a7db80195c0babb1195ef34`) and `canonical_run_seal_v1.json` (SHA-256: `ae7a9ada86927a79e0c6916b44d3f0ba9e1f9756df55dd7b2fce712b35d48701`). Across the 5 experimental conditions (`no_rag`, `rag_k1`, `rag_k3`, `rag_k5`, `rag_k10`), all 1,280 TEST views were dispatched sequentially (`concurrency = 1`), producing **6,400 terminal execution records** across **6,401 physical API attempts** (6,387 VALID responses and 13 INCOMPLETE responses; 99.80% VALID fraction). Within the **718 scorable mapped-positive TEST views** ($5 \times 718 = 3{,}590$ dispatches), the provider failure rate, JSON parse failure rate, and invalid ATT&CK ID rate were identically **0.00% (0/3,590)**.

4.2. Presentation of Data

We present the canonical empirical tables and publication figures organized sequentially across Research Questions RQ1 (Tables 4, 5, 6, 7; Figures 2, 3), RQ2 (Table 8; Figures 4, 5), and RQ3 & Integrated Failure Synthesis (Tables 9, 10; Figures 6, 7, 8).

Table 4: Primary Attribution Performance, 474-Class Macro-F1 Bootstrap CIs, and Ground-Truth Complexity Across Conditions.

Condition	Depth (*k*)	Scorable (*N*)	Headline Acc_{e2e} (95% Cluster CI)	ΔAcc vs. No-RAG (95% CI)	474-Class Macro-F1 (0–1)	ΔMacro-F1 (95% Cluster CI)	Single-GT (N=678)	Multi-GT (N=40)
`no_rag`	0	718	77.99% [74.64%, 80.88%]	Baseline	0.012608 (1.26%)	Baseline	77.43%	87.50%
`rag_k1`	1	718	77.02% [73.50%, 80.17%]	-0.975 pp [-3.186, +1.124]	0.012668 (1.27%)	+0.000060 [-0.000242, +0.000363]	75.66%	100.00%
`rag_k3`	3	718	78.55% [75.00%, 81.74%]	+0.557 pp [-2.786, +3.934]	0.013643 (1.36%)	+0.001034 [+0.000632, +0.001424]	77.29%	100.00%
`rag_k5`	5	718	78.83% [75.07%, 82.35%]	+0.836 pp [-2.934, +4.603]	0.013891 (1.39%)	+0.001282 [+0.000860, +0.001679]	77.58%	100.00%
`rag_k10`	10	718	79.53% [75.81%, 82.85%]	+1.532 pp [-2.355, +5.300]	0.014024 (1.40%)	+0.001415 [+0.001011, +0.001792]	78.32%	100.00%

**Note on Table 4: 95% confidence intervals for both* ΔAcc *and* ΔMacro-F1 *relative to* `no_rag` *are computed via 1,000 cluster-bootstrap resamples over the 440 TEST scenario clusters (*`seed=42`, `canonical_metric_bundle_v2.json`*). While* ΔAcc *CIs span zero across all k,* ΔMacro-F1 *CIs exclude zero for* $k \in \{3, 5, 10\}$.

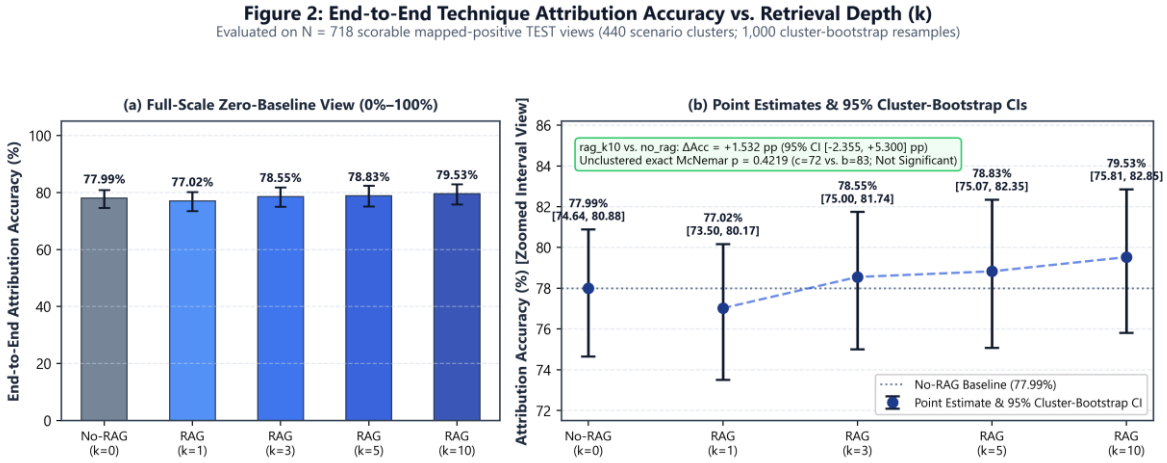


Figure 2: Attribution Accuracy vs. Candidate Depth k across Conditions (N=718 Scorable Views with 95% Bootstrap CI).

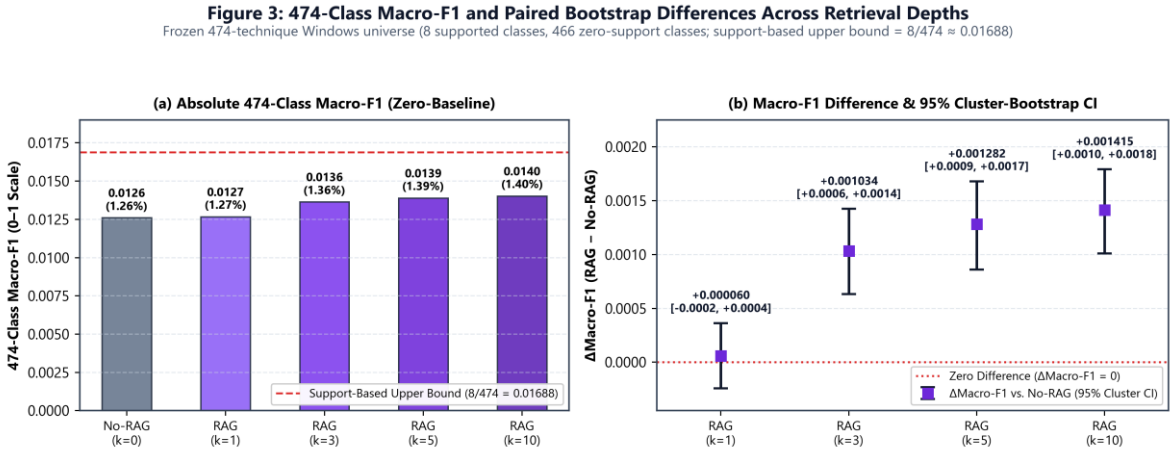


Figure 3: 474-Class Macro-F1 Performance across Retrieval Depths (8 Active Supported Classes vs. 466 Zero-Support Universe Classes).

Table 5: Attribution Diagnostic Metrics Across Experimental Conditions.

Condition	Scorable Views (*N*)	Completed Outputs (of 1,280)	Parse Failures	Invalid ATT&CK IDs	Invalid ID Rate (%)
`no_rag`	718	1,280	0	0	0.00%
`rag_k1`	718	1,280	0	0	0.00%
`rag_k3`	718	1,274	0	0	0.00%
`rag_k5`	718	1,277	0	0	0.00%
`rag_k10`	718	1,276	0	0	0.00%

Table 6: Representation Stratification: Single-Event vs. Contextual-Event Views.

Condition	Single-Event Acc_{e2e} (N=278)	Contextual-Event Acc_{e2e} (N=440)	Single Macro-F1	Contextual Macro-F1	ΔAcc (Context - Single)
no_rag	87.05%	72.27%	0.0133 (1.33%)	0.0120 (1.20%)	-14.78 pp
rag_k1	85.61%	71.59%	0.0131 (1.31%)	0.0121 (1.21%)	-14.02 pp
rag_k3	84.17%	75.00%	0.0129 (1.29%)	0.0130 (1.30%)	-9.17 pp
rag_k5	83.45%	75.91%	0.0129 (1.29%)	0.0131 (1.31%)	-7.54 pp
rag_k10	83.81%	76.82%	0.0129 (1.29%)	0.0132 (1.32%)	-6.99 pp

Table 7: Paired Scorable Representation Concordance and Unclustered McNemar Discordance (N=278 complete pairs).

Condition	Complete Pairs (N)	Single Paired Acc	Contextual Paired Acc	Paired Δ	Both Correct	Single Only	Contextual Only	Both Incorrect	McNemar p_{exact}
no_rag	278	87.05%	92.45%	+5.40 pp	228	14	29	7	0.0315
rag_k1	278	85.61%	92.45%	+6.83 pp	229	9	28	12	0.0026
rag_k3	278	84.17%	88.85%	+4.68 pp	225	9	22	22	0.0294
rag_k5	278	83.45%	85.25%	+1.80 pp	221	11	16	30	0.4421
rag_k10	278	83.81%	83.81%	+0.00 pp	216	17	17	28	1.0000

Table 8: Decoupled Failure Decomposition Matrix Across Independent Diagnostic Axes (D2i).

Condition	Total Errors	Retrieval Miss ($Y_i \cap R_{i,k} = \emptyset$)	Selection Failure ($Y_i \cap R_{i,k} \neq \emptyset \wedge$ Wrong)	Miss & Wrong Overlap ($Y_i \cap R_{i,k} = \emptyset \wedge$ Wrong)	Correct Despite Miss ($Y_i \cap R_{i,k} = \emptyset \wedge$ Correct)	Invalid ID / Parse / Provider Failure
no_rag	158	N/A	N/A	N/A	N/A	0 / 0 / 0
rag_k1	165	691 (96.24%)	0	165 (100.00%)	526	0 / 0 / 0
rag_k3	154	600 (83.57%)	3	151 (98.05%)	449	0 / 0 / 0
rag_k5	152	545 (75.91%)	5	147 (96.71%)	398	0 / 0 / 0
rag_k10	147	397 (55.29%)	28	119 (80.95%)	278	0 / 0 / 0

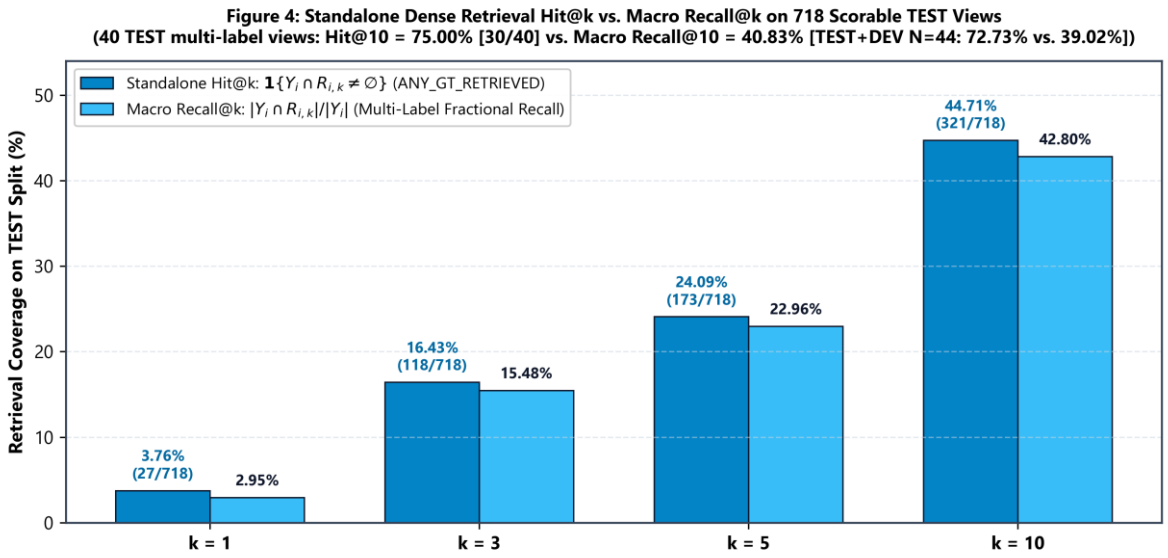


Figure 4: Standalone Retrieval Hit@k vs. Multi-Label Macro Recall@k across Depths k=1, 3, 5, 10 on 718 Scorable TEST Views.

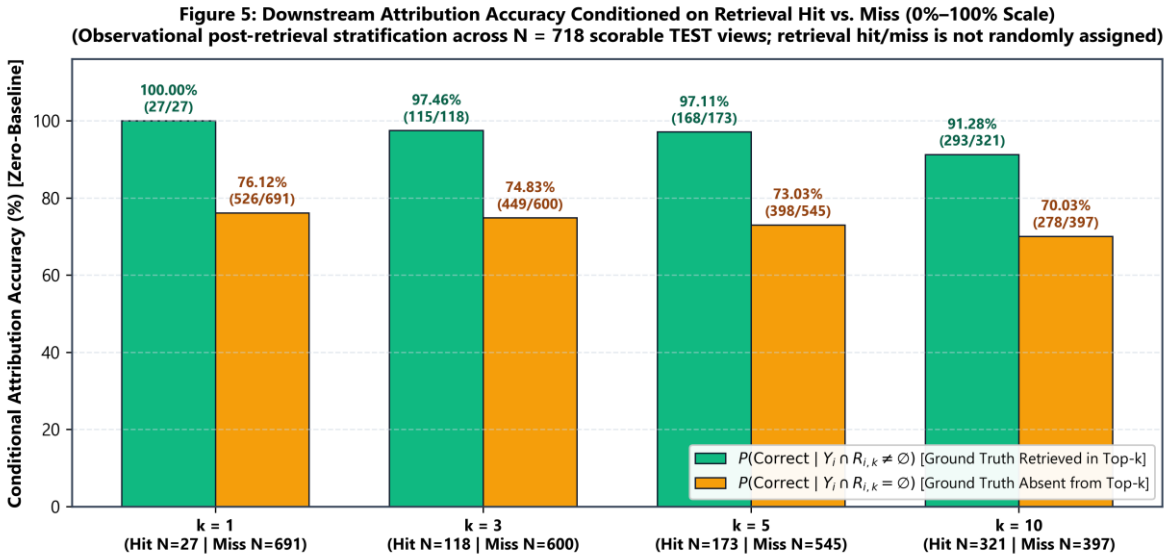


Figure 5: Post-Retrieval Stratum Accuracy: P(Correct | Hit) vs. P(Correct | Miss) across Retrieval Depths.

Table 9: Resource Consumption, Latency Scaling, Token-Usage Cost, and Conservative Ledger Spend.

Condition	Total Input Tokens	Total Output Tokens	Mean Output / Req	Mean Latency	Median Latency	Usage Estimated Cost (USD)	Conservative Ledger Spend (USD)*	Mean Ledger / Query (USD)
`no_rag`	863,139	209,466	163.6	2.90s	2.30s	USD 0.4671	USD 0.4671 (0.47)	USD 0.000365
`rag_k1`	1,595,554	299,128	233.7	3.51s	2.62s	USD 0.7575*	USD 1.2972 (1.30)*	USD 0.001013*
`rag_k3`	2,780,640	403,100	314.9	4.22s	2.74s	USD 1.1789	USD 1.1789 (1.18)	USD 0.000921
`rag_k5`	3,917,047	419,880	328.0	4.33s	2.87s	USD 1.4831	USD 1.4831 (1.48)	USD 0.001159
`rag_k10`	6,546,274	427,346	333.9	4.37s	2.67s	USD 2.1494	USD 2.1494 (2.15)	USD 0.001679

**Note on Table 9 (`rag_k1` Cost Reconciliation & Scope): All resource and cost figures in Table 9 cover the full 1,280 logical TEST requests per condition (6,400 logical requests / 6,401 physical attempts total) and represent tariff-derived accounted costs under the API budget guard (`config/pricing_v1.json`; external commercial invoice verification is absent). For `rag_k1`, pre-credit token-usage estimated cost is* USD 0.75784210 *(≈* USD 0.7578*), less* USD 0.00035420 *observed cache credit =* USD 0.75748790 *(≈* USD 0.7575 *net usage cost). Conservative ledger spend is* USD 0.75748790 + USD 0.53974560 = USD 1.29723350 *(≈* USD 1.2972*, or* USD 0.001013*/query) because 1 transient attempt on `view_d870d574` lacked a usage receipt and retained its full pre-dispatch worst-case hold of* USD 0.53974560 *per Protocol Decision D5.*

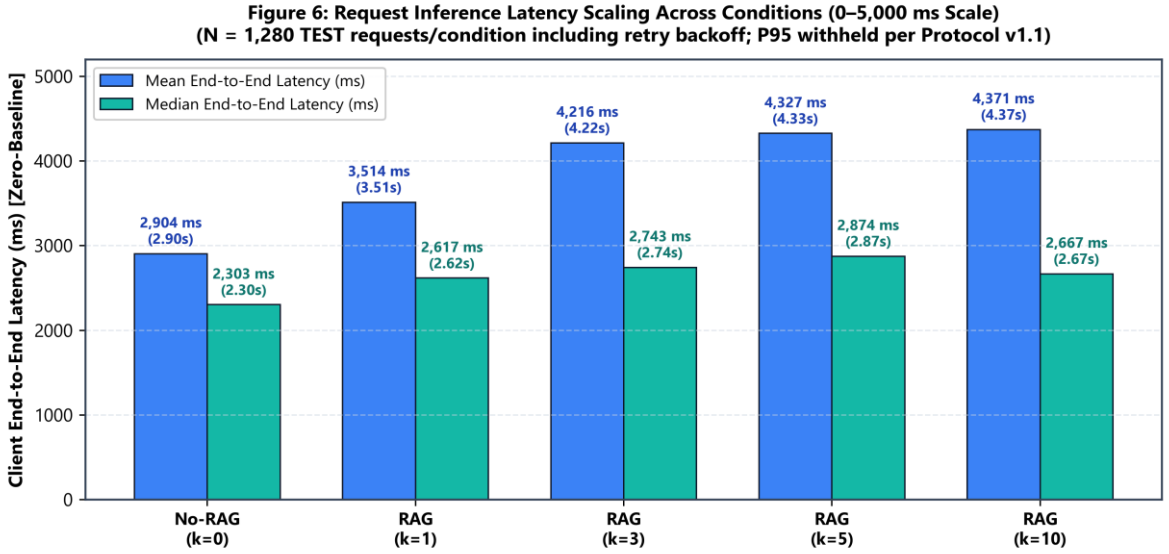


Figure 6: Request Inference Latency Scaling: Mean and Median Duration (ms) across Conditions (P95 Withheld per Protocol).

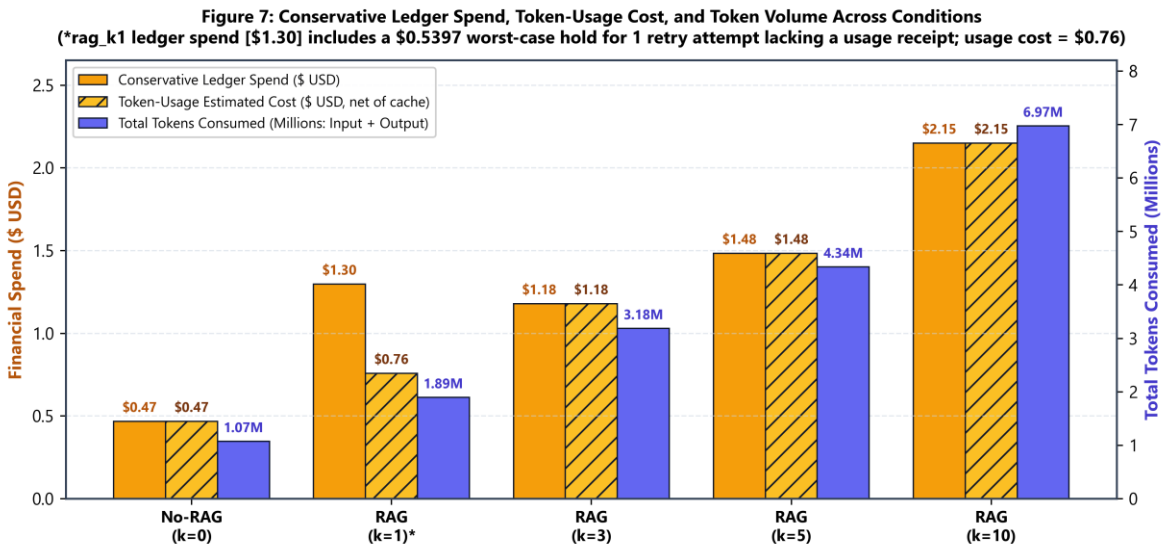


Figure 7: Conservative Ledger Spend vs. Token-Usage Cost (USD) and Aggregate Input Token Volume.

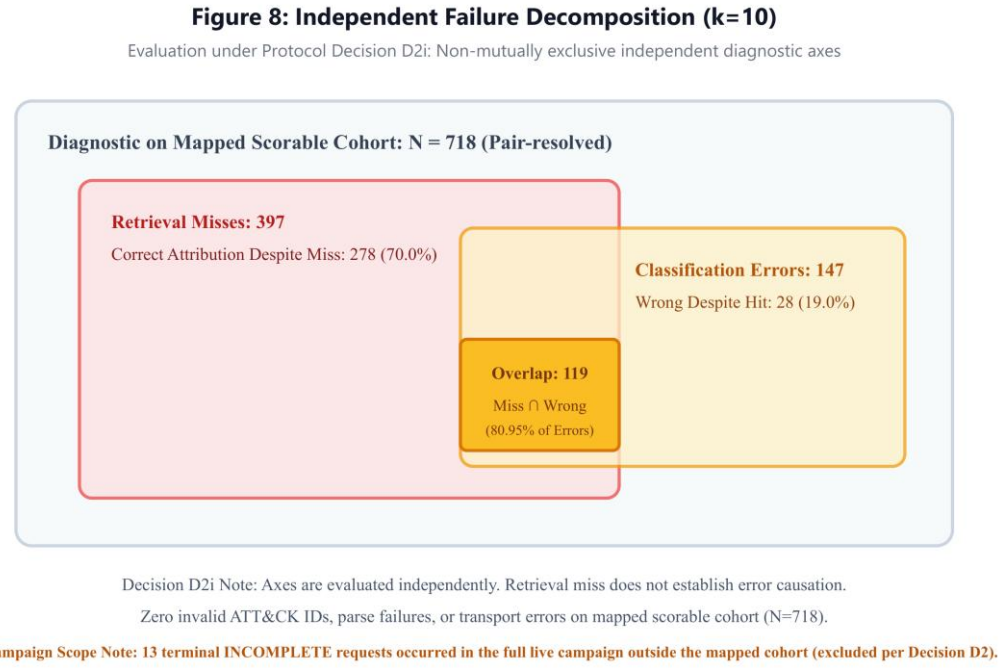


Figure 8: Decoupled Independent Failure Decomposition and Co-occurrence Breakdown at Retrieval Depth k=10.

Table 10: Whole-Study Financial Ledger and Budget Reconciliation.

Accounting Dimension	Ledger Field Identifier	Value	Currency
Total Study Authorized Budget Ceiling	`total_study_budget_usd`	19.9900	USD
Canonical Conditions Total Ledger Spend	`canonical_conditions_total_usd`	6.5758	USD
Prior Pilot Exploratory Hold	`prior_pilot_provisional_hold_usd`	0.0526	USD
Active Unsettled Reservations	`active_reservations_usd`	0.0000	USD
Orphaned Budget Claims	`orphan_reservations_usd`	0.0000	USD
Total Study Committed Spend	`total_study_committed_spend_usd`	6.6284	USD
Net Remaining Uncommitted Budget	`net_remaining_uncommitted_budget_usd`	13.3616	USD

4.3. Analysis of Results

1. Analysis of RQ1: End-to-End Attribution Efficacy — Accuracy vs. 474-Class Macro-F1

Across the 718 scorable mapped-positive TEST views (Table 4), retrieval depth k=10 (`rag_k10`) achieved the highest observed point estimate for headline end-to-end accuracy at **79.53% (571/718 correct)** compared to the unaugmented baseline (`no_rag`: **77.99%, 560/718 correct**), representing an observed difference of ΔAcc = +1.532 percentage points (+11 net views), while 474-class Macro-F1 increased from **0.012608 (1.26%)** to **0.014024 (1.40%)**. Intermediate retrieval depths yielded **77.02% (553/718, ΔAcc = -0.975 pp, Macro-F1 0.012668)** at k=1, **78.55% (564/718, ΔAcc = +0.557 pp, Macro-F1 0.013643)** at k=3, and **78.83% (566/718, ΔAcc = +0.836 pp, Macro-F1 0.013891)** at k=5. On the 40 multi-GT views, all four RAG conditions achieved **100.00% (40/40)** accuracy compared to **87.50% (35/40)** under `no_rag`.

Critically, answering RQ1 completely requires reporting the distinct statistical inference outcomes for **Accuracy** versus **474-class Macro-F1** recorded in `canonical_metric_bundle_v2.json`:

- **End-to-End Accuracy Difference (Not Statistically Significant):** The 95% cluster-bootstrap confidence intervals (1,000 resamples over 440 scenario clusters, `seed=42`) for ΔAcc relative to `no_rag` contain zero across all four RAG depths: ΔAcc_{k1} = [-3.186 pp, +1.124 pp], ΔAcc_{k3} = [-2.786 pp, +3.934 pp], ΔAcc_{k5} = [-2.934 pp, +4.603 pp], and ΔAcc_{k10} = [-2.355 pp, +5.300 pp]. For `rag_k10` versus `no_rag`, the unclustered view-level discordant counts are: both correct = 488, `no_rag` only = 72, `rag_k10` only = 83, and both incorrect = 75, yielding an exact two-sided McNemar p = 0.4219 (p = 0.435 for k=1, p = 0.777 for k=3, p = 0.677 for k=5).
- **474-Class Macro-F1 Difference (Positive Cluster-Bootstrap CIs at k ∈ {3, 5, 10} and 8-Class F1 Decomposition):** At k=10, the 474-class Macro-F1 difference over `no_rag` was

+0.001415 (+0.1415 pp on a 0–100% scale, a +11.23% relative gain), with a nominal 95% cluster-bootstrap confidence interval of **[+0.001011, +0.001792]** that excludes zero. Positive 95% cluster-bootstrap CIs excluding zero were likewise observed at k=3 (ΔMacro-F1 = +0.001034, 95% CI [+0.000632, +0.001424]) and k=5 (ΔMacro-F1 = +0.001282, 95% CI [+0.000860, +0.001679]), whereas k=1 spanned zero (+0.000060, 95% CI [-0.000242, +0.000363]). Per-class decomposition (`per_technique_metrics.json`) explains the difference between the observed point-estimate changes in Accuracy and Macro-F1 (while statistical uncertainty is assessed separately using the nominal, unadjusted pair-cluster bootstrap confidence intervals): in view-weighted Accuracy (1/718 per view), the 83 newly corrected views (b=83) are largely offset by 72 regressions (c=72, net +11 views). In class-weighted Macro-F1 (1/474 per class), however, `T1685.005` (N=60) jumps from F1 = 0.0000 (TP=0 in `no_rag`) to F1 = 0.9916 (TP=59, Δ F1 = +0.9916). Specifically, among the 60 TEST views whose ground-truth sets contain `T1685.005`, `no_rag` predicts retired `T1070.001` in 55 views and predicts `T1543.003` in 5 multi-GT views labeled with both `T1543.003` and `T1685.005` (`view_339041eb`, `view_6c60a0e0`, `view_72d3654e`, `view_d3e487ef`, `view_e96ca934`); those 5 predictions are scored as correct under `ANY_MATCH` accuracy but contribute false negatives (FN) for `T1685.005` in per-class F1, so TP=0 for `T1685.005` does not mean 60 incorrect view-level predictions. Accompanied by gains on `T1059.001` (0.7186 → 0.7653, Δ F1 = +0.0467) and `T1059.003` (0.7108 → 0.7558, Δ F1 = +0.0450) while `T1547.001` remains at 1.0000 (Δ F1 = 0.0000), these positive class gains (+1.0833 combined) outweigh the moderate F1 decreases across the four larger classes—`T1053.005` (0.9444 → 0.8606, -0.0838), `T1543.003` (0.9763 → 0.8866, -0.0897), `T1136.001` (0.7742 → 0.6620, -0.1122), and `T1105` (0.8520 → 0.7254, -0.1266; combined -0.4124)—raising the 8-class F1 sum from 5.9764 (mean 0.7470 over 8 supported classes; 0.012608 over 474 classes) to 6.6473 (mean 0.8309 over 8 classes; 0.014024 over 474 classes, net +0.6709 / 474 = +0.001415).

In the paired representation analysis across the **278 complete scorable pairs** (Table 7), Contextual views outperformed Single views under `no_rag` (92.45% vs. 87.05%, Δ = +5.40 pp, unclustered exact McNemar p_{exact} = 0.0315) and `rag_k1` (92.45% vs. 85.61%, Δ = +6.83 pp, p_{exact} = 0.0026), converging to +0.00 pp (83.81% vs. 83.81%, p_{exact} = 1.0000) at k=10. Forensic stratification reveals that of the 278 complete pairs, 238 have identical ground-truth sets while 40 multi-stage pairs have expanded ground-truth sets on the contextual view: 12 of the 15 net contextual wins in `no_rag` (80%) and all 19 of the 19 net contextual wins in `rag_k1` (100%) occurred within the 40 mismatched-GT pairs, indicating that apparent contextual differences co-occur with multi-stage label expansion rather than isolating a purely causal effect of context window length.

2. Analysis of RQ2: Standalone Hit@k vs. Macro Recall@k and Post-Retrieval Failure Axes

Across the 718 scorable TEST views (`retrieval_metrics.json` and `retrieval_conditional_metrics.json`), standalone dense retrieval (`all-MiniLM-L6-v2` + FAISS `IndexFlatIP`) achieved sample-level **Hit@k (`ANY_GT_RETRIEVED`)** of **Hit@1 = 3.76% (`27/718` hits, `691` misses)**, **Hit@3 = 16.43% (`118/718` hits, `600` misses)**, **Hit@5 = 24.09% (`173/718` hits, `545` misses)**, and **Hit@10 = 44.71% (`321/718` hits, `397` misses = 55.29% miss rate)**. Because 40 scorable TEST views carry multiple ground-truth labels (`mapped_multi`), sample-averaged **multi-label Macro Recall@k** is systematically lower than Hit@k: **Macro Recall@1 = 2.95%**, **Macro Recall@3 = 15.48%**, **Macro Recall@5 = 22.96%**, and **Macro Recall@10 = 42.80%** (specifically, on the **40 TEST multi-label views**, Hit@10 = 75.00% [`30/40`] whereas sample-averaged Macro Recall@10 = 40.83% [sum of fractional recalls = 49/3 ≈ 16.3333 divided by 40], and on the **678 TEST single-label views**, Hit@10 = Macro Recall@10 = 42.92% [`291/678`]; in the exploratory **TEST+DEV combined cohort** [N=756: `712` single-GT + `44` multi-GT], the **44 multi-label views** achieve Hit@10 = 72.73% [`32/44`] vs. Macro Recall@10 = 39.02% [sum of fractional recalls = 103/6 divided by 44], and the **712 single-label views** achieve 43.40% [`309/712`]). Comparing post-retrieval sample strata at k=10 (Table 8, Figure 5) shows:

- **Retrieved Stratum ($Y_i \cap R_{i,10} \neq \emptyset$, N=321):** Downstream attribution accuracy in this subset is **$P(\text{Correct} \mid Y_i \cap R_{i,10} \neq \emptyset) = 91.28\%$ (`293/321`)**, with 28 downstream selection discrepancies.
- **Missed Stratum ($Y_i \cap R_{i,10} = \emptyset$, N=397):** Downstream attribution accuracy in this subset is **$P(\text{Correct} \mid Y_i \cap R_{i,10} = \emptyset) = 70.03\%$ (`278/397`)**, with **119 misclassifications** (an observed between-stratum difference of 21.25 pp).
- **Error Co-occurrence Locus:** At k=10, **119 of 147 classification errors (80.95%)** co-occurred with retrieval misses. This strong observational association motivates retrieval-focused ablations without claiming direct interventional causality.

3. Analysis of RQ3: Token Volume vs. Cost Scaling, Latency, and Ledger Reconciliation

As retrieval depth increases from `no_rag` to `rag_k10` (Table 9, Figures 6–7), we explicitly separate **input token volume scaling** from **monetary cost scaling**:

- **Input & Output Token Scaling:** Aggregate input tokens across the 1,280 TEST views scale **7.58-fold** from **863,139** (`674.3` tokens/req in `no_rag`) to **6,546,274** (`5,114.3` tokens/req in `rag_k10`), while mean output tokens (including internal reasoning) scale **2.04-fold** from **163.6** (`209,466` total) to **333.9** (`427,346` total) tokens/req.
- **Token-Usage Cost vs. Conservative Ledger Spend (`rag_k1` vs. `rag_k3` Reconciliation):** Across all 1,280 logical TEST requests per condition (tariff-derived accounted costs under `config/pricing_v1.json`), both token-usage estimated cost and conservative ledger spend scale **4.60-fold** from **USD 0.4671** (`$0.46714395`, `$0.000365`/query) in `no_rag` to **USD 2.1494**

($2.14938370, $0.001679/query) in rag_k10 (with rag_k3 at **USD 1.1789** [$1.17888000] and rag_k5 at **USD 1.4831** [$1.48311775]). Notably, in Table 9, rag_k1 exhibits a higher conservative ledger spend (**USD 1.29723350 ≈ USD 1.30**) than rag_k3 (**USD 1.17888000 ≈ USD 1.18**) despite consuming 42.6% fewer input tokens (1,595,554 vs. 2,780,640). Audit of budget_ledger.json and request_journal.jsonl (lines 48476–48485) explains this exact reconciliation: across the 6,400 logical requests, there were **6,401 physical API attempts**, with the single extra attempt occurring on ("view_d870d574", "rag_k1") (rag_k1_predictions.jsonl line 1078). Because the failed initial attempt on view_d870d574 did not return a provider usage receipt, the financial guard (Protocol D5) conservatively retained its full worst-case pre-dispatch reservation hold of **USD 0.53974560** alongside the net token-usage cost of **USD 0.75748790** (pre-credit token_usage_estimated_cost_usd USD 0.75784210 less USD 0.00035420 observed cache credit), summing to USD 0.75748790 + USD 0.53974560 = USD 1.29723350. All 13 INCOMPLETE responses reaching the 8,192 output token limit occurred exclusively in non-scorable views (11 unmapped, 2 ambiguous). Total canonical conservative ledger spend was **USD 6.57575890** (**USD 6.62839900** total committed spend including the **USD 0.05264010** pilot hold), leaving **USD 13.36160100** (66.84%) in uncommitted budget beneath the **USD 19.99** ceiling.

4.4. Interpretation of Results

Four core observational patterns and a concrete multi-view worked example illuminate the empirical results observed in Chapter 4 (noting that these patterns are consistent with hypotheses involving lexical mismatch, competing retrieved techniques, and context dilution, while the present observational diagnostics do not isolate these mechanisms causally):

1. **Candidate Pool Size and k=1 Distractor Co-occurrence (77.02% vs. 77.99% No-RAG):** Because Hit@1 is only 3.76% (27/718), in **96.24% (691/718)** of scorable views at rag_k1, the single injected document does not match the ground-truth technique. Presenting a single non-matching ATT&CK document coincides with an observed -0.975 pp accuracy dip relative to no_rag, whereas expanding the candidate pool to k ≥ 3 (Hit@3 = 16.43%, Hit@10 = 44.71%) coincides with higher observed accuracy (78.55% → 79.53%), consistent with the hypothesis that broader candidate sets mitigate single-document distraction.
2. **Reconciling the 21.25 pp Between-Stratum Difference with the +1.532 pp Marginal Difference:** First, gpt-5.6-luna (xhigh) already exhibits high baseline accuracy on Windows attack commands (77.99% No-RAG baseline, and 70.03% in the missed stratum at k=10). Second, because the dense bi-encoder misses the ground truth in **55.29% (397/718)** of views at k=10, retrieved ground-truth definitions are present in less than half of the benchmark, which is consistent with the modest marginal end-to-end difference.
3. **Per-Technique Retrieval Breakdown — Scorable TEST (N=718) vs. Combined TEST+DEV (N=756, T20):** To prevent any conflation between the 718 scorable TEST cohort and the 756-view combined TEST+DEV diagnostic cohort reported in reports/T20_retrieval_diagnostics.md (718 TEST + 38 scorable DEV views), we report

both cohorts side-by-side: on the **718 scorable TEST cohort** (with combined TEST+DEV T20 rates in parentheses), `T1685.005` achieves **98.33% Hit@10 (`59/60` TEST; `98.39%`, `61/62` TEST+DEV)**, `T1547.001` achieves **92.86% (`91/98` TEST; `92.45%`, `98/106` TEST+DEV)**, `T1059.001` achieves **68.22% (`73/107` TEST; `68.14%`, `77/113` TEST+DEV)**, `T1053.005` achieves **47.06% (`40/85` TEST; `45.16%`, `42/93` TEST+DEV)**, and `T1543.003` achieves **31.48% (`34/108` TEST; `30.70%`, `35/114` TEST+DEV)**. Conversely, `T1105` (*Ingress Tool Transfer*) achieves **16.67% Hit@10 (`18/108` TEST; `15.79%`, `18/114` TEST+DEV)** (where competing LOLBin techniques such as `T1218.012` *Verclsid* rank #1 in 42.1% of T20 `T1105` views), `T1059.003` achieves **14.02% (`15/107` TEST; `17.12%`, `19/111` TEST+DEV)**, and `T1136.001` (*Create Account: Local Account*) exhibits **0.00% Hit@10 (`0/95` TEST; `0/99` TEST+DEV)**. Specifically, across the **95 TEST views** with ground truth `T1136.001`, **70 views** contain Security `EventID=4720` across unordered EventID set combinations (`10` single-event `{4720}` views, `38` contextual `{4688, 4720}` views [comprising both temporal orderings], `12` contextual `{1, 4720}` views, and `10` contextual `{13, 4720}` views, where `EventID=4720` records contain the 6 allowlisted schema fields `TimeCreated`, `Computer`, `EventID`, `TargetUserName`, `SubjectUserName`, and `SubjectLogonId`), while **25 single-event views** contain process-creation telemetry without `EventID=4720` (`13` Security `EventID=4688` views and `12` Sysmon `EventID=1` views, such as `New-LocalUser` in `view_02aac5b1`). These low retrieval rates are consistent with hypotheses of lexical mismatch and competing LOLBin descriptions, without isolating a single mechanism causally.

4. **Multi-Event Retrieval Rank Shifts — Scorable TEST Pairs (N=278) vs. Combined TEST+DEV Pairs (N=296, T20):** Under the Top-10-censored rank comparison rule (`comparison_rank = rank if found else 11` for each pair's anchor technique), on the **278 complete scorable TEST pairs**, multi-event contextual views exhibit a **worse (larger) anchor-technique `comparison_rank` in 21.58% of pairs (`60/278`)**, a **better (smaller) rank in 7.55% (`21/278`)**, and a **tied `comparison_rank` in 70.86% (`197/278`, comprising `58` pairs tied at a finite Top-10 rank `1..10` and `139` pairs absent from Top-10 [`rank = 11`] in both views)**. In the exploratory combined TEST+DEV diagnostic cohort (**296 anchor pairs** in `reports/T20_retrieval_diagnostics.md`, comprising 278 TEST + 18 DEV pairs), contextual views exhibit a worse rank in **21.96% (`65/296`)**, a better rank in **7.77% (`23/296`)**, and a tied `comparison_rank` in **70.27% (`208/296`, comprising `61` finite-rank ties and `147` absent-in-both ties)**. This asymmetry is consistent with a context-dilution hypothesis when multi-event windows are pooled into a single 384-d `all-MiniLM-L6-v2` vector, though observational rank comparisons do not isolate background-event dilution causally.

5. Concrete End-to-End Worked Examples From Canonical Artifacts (`view_0265275a`, `view_02aac5b1` & `view_0f68fd96`)

To illustrate the exact mechanics of dense retrieval, taxonomy evolution recovery, distractor co-occurrence, and `T1136.001` retrieval misses on verbatim benchmark records from `data/ground_truth/synthetic/inference.jsonl` (where every displayed `endpoint_evidence`

JSON array below is programmatically serialized via `json.dumps(json.loads(record["endpoint_evidence"]), indent=2)` directly from `inference.jsonl` with zero added or omitted keys), `artifacts/retrieval/retrieval_diagnostics.jsonl`, and `artifacts/results/predictions/`, consider three scorable TEST views:

```
# Case 1: Treatment-Win Discordant View via RAG at k >= 3 (sample_id='view_0265275a',
contextual, GT=['T1685.005'])
# Exact endpoint_evidence JSON array from data/ground_truth/synthetic/inference.jsonl:
[
  {
    "CommandLine": "C:\\ProgramData\\pine_aspen_oak_83671d\\loghelper.exe --api
EvtClearLog --channel Security --archive
C:\\ProgramData\\pine_aspen_oak_83671d\\security.evtx",
    "Computer": "EXCH01",
    "EventID": 4688,
    "NewProcessId": "0x582c",
    "NewProcessName": "C:\\ProgramData\\pine_aspen_oak_83671d\\loghelper.exe",
    "ParentProcessName": "C:\\Windows\\explorer.exe",
    "ProcessId": "0x5824",
    "SubjectLogonId": "0x5829",
    "SubjectUserName": "wlee",
    "TargetUserName": "wlee",
    "TimeCreated": "2026-05-03T13:35:02Z"
  },
  {
    "Computer": "EXCH01",
    "EventID": 1102,
    "SubjectLogonId": "0x5829",
    "SubjectUserName": "wlee",
    "TimeCreated": "2026-05-03T13:35:05Z"
  }
]
# FAISS Top-5 Retrieved Ranks: #1 T1547.004 (0.4031), #2 T1546.009 (0.4001), #3
T1685.005 (0.4000, active v19.2 ID),
#   #4 T1685.001 (0.3977), #5 T1218.010 (0.3620)
# Model Predictions across Conditions (1 of b=83 treatment-win discordant views at
k=10):
#   no_rag -> 'T1070.001' (Incorrect: retired pre-v19.2 ID) | rag_k1 -> 'T1070.001'
(Incorrect: Rank #1 is T1547.004)
#   rag_k3 -> 'T1685.005' (CORRECT: T1685.005 enters at Rank #3) | rag_k5 ->
'T1685.005' | rag_k10 -> 'T1685.005'
```

```
# Case 2: Baseline-Win Regression on Single-Event Process Creation
(sample_id='view_02aac5b1', single, GT=['T1136.001'])
# Exact endpoint_evidence JSON array from data/ground_truth/synthetic/inference.jsonl
(all 15 keys verbatim):
[
  {
    "CommandLine": "\"C:\\Program Files\\PowerShell\\7\\pwsh.exe\" -Command \"New-
LocalUser -Name svc_03672e -AccountNeverExpires -Description fir_ash_larch_03672e\"",
    "Computer": "WEB01",
    "EventID": 1,
    "Hashes":
"SHA256=656870b7a837ffb1e8c22c3dc5bfb387c113804399f06d16fa6a7a1dba65bb4d",
    "Image": "C:\\Program Files\\PowerShell\\7\\pwsh.exe",
    "LogonGuid": "{d733464a-6d27-dbb6-3fcb-ac48c28e90d5}",
    "LogonId": "0x10ec9",
    "ParentCommandLine": "C:\\Windows\\explorer.exe",
    "ParentImage": "C:\\Windows\\explorer.exe",
    "ParentProcessGuid": "{f5fbee96-81ce-9e35-b440-f6776f5daa1b}",
    "ParentProcessId": 69316,
    "ProcessGuid": "{ff105a13-d578-e29c-81cb-a13ea71ac000}",
    "ProcessId": 69320,
    "User": "agarcia",
    "UtcTime": "2026-02-19T08:55:54Z"
  }
]
# FAISS Top-5 Retrieved Ranks: #1 T1547.004 (0.4334), #2 T1003.002 (0.3863), #3
T1059.001 (0.3711, PowerShell),
#   #4 T1216.001 (0.3651), #5 T1556.008 (0.3645)  --> GT 'T1136.001' ABSENT from Top-10
(0/95 TEST views)
# Model Predictions across Conditions (1 of c=72 baseline-win discordant regressions at
k=10):
#   no_rag -> 'T1136.001' (CORRECT) | rag_k1 -> 'T1136.001' (CORRECT)
#   rag_k3 -> 'T1059.001' (Incorrect: changes to T1059.001 at k>=3 as Rank #3
PowerShell enters context under miss;
#              consistent with context distraction without isolating single cause) |
rag_k5, rag_k10 -> 'T1059.001'

# Case 3: EventID 4720 Account-Creation View (sample_id='view_0f68fd96', single,
GT=['T1136.001'])
# Exact endpoint_evidence JSON array from data/ground_truth/synthetic/inference.jsonl
(all 6 keys verbatim):
[
  {
    "Computer": "EXCH01",
    "EventID": 4720,
    "SubjectLogonId": "0x50f9",
    "SubjectUserName": "agarcia",
    "TargetUserName": "svc_21083a",
    "TimeCreated": "2026-05-14T18:39:17Z"
  }
]
# FAISS Top-5 Retrieved Ranks: #1 T1685.005 (0.1624), #2 T1685.001 (0.1438), #3 T1217
(0.1412), #4 T1087.001 (0.1326),
#   #5 T1124 (0.1298)  --> GT 'T1136.001' ABSENT from Top-10; all conditions predict
'T1136.001' (CORRECT despite miss)
```

4.5. Comparison with Literature

Comparing RAG2ATT&CK's empirical findings against the eight audited comparators highlights why domain-specific evaluation controls are essential:

- **Contrast with CloudTrail RAG (Adediran et al., 2026) [10]:** Whereas Adediran et al. reported large end-to-end RAG gains on 200 AWS CloudTrail events using Gemini 2.5 Pro and a two-step query-expansion pipeline on Vertex AI, our single-step dense retrieval on raw Windows logs with `gpt-5.6-luna` yields a modest, statistically non-significant +1.532 pp accuracy difference alongside a +0.001415 Macro-F1 difference. Because the two studies differ across telemetry domain, model family, and retrieval pipeline architecture, this contrast suggests the hypothesis—rather than proving causally in isolation—that single-step dense retrieval over raw Windows OS fields faces a steeper lexical-semantic representation gap than query-expanded cloud API logs.
- **Alignment with CTI Distractor Findings (TechniqueRAG [5] & H-TechniqueRAG [6]):** Our observation that `rag_k1` dips slightly below `no_rag` (-0.975 pp) when the top-1 miss rate is 96.24%, while accuracy in the retrieved stratum reaches 91.28%, is consistent with the distractor-sensitivity patterns reported by Morbiato et al. [6] on unstructured CTI prose.
- **Advancement over Fixed-Cutoff Telemetry Studies (Trace2ATT&CK [11], CAM-LDS [8], LADE [12]):** Unlike Trace2ATT&CK [11] (which fixes both retriever depth and output cutoff at 5 on Linux eBPF graphs) and CAM-LDS [8] / LADE [12] (which vary output cutoff `Top-k` without RAG), RAG2ATT&CK's decoupled ablation across $k \in \{1, 3, 5, 10\}$ separately characterizes input token growth (7.58x at k=10), ledger cost scaling (4.60x at k=10), sample-level Hit@k (44.71% at k=10), and multi-label Macro Recall@k (42.80% at k=10).

4.6. Implications of the Results

For SOC architects and cybersecurity AI practitioners, our diagnostic findings motivate three testable engineering hypotheses for production RAG design:

1. **Prioritize Retrieval Engineering Before Scaling Context Windows:** Because 80.95% (`119/147`) of errors at k=10 co-occur with retrieval misses—while accuracy in the retrieved stratum reaches 91.28%—expanding context depth from k=0 to k=10 increases input token volume by **7.58x** and monetary cost by **4.60x** while leaving 55.29% of queries without ground-truth context. Improving upstream candidate recall is therefore the highest-leverage intervention to test next.
2. **Test Hybrid Lexical-Dense Retrieval and Schema Translation for Windows Event IDs:** Off-the-shelf general-purpose bi-encoders (`all-MiniLM-L6-v2`) achieved `0.00% Hit@10` (`0/95` TEST views) on `T1136.001` across both the 70 views containing Security `EventID=4720` (`TimeCreated`, `Computer`, `EventID`, `TargetUserName`, `SubjectUserName`, `SubjectLogonId`) and the 25 single-event process-creation views (`13 EventID=4688 + 12 EventID=1`). Consistent with a lexical-mismatch hypothesis, this motivates testing hybrid sparse-dense

retrieval (BM25 + dense embeddings with cross-encoder reranking) and schema-aware query expansion mapping Event IDs to canonical ATT&CK concepts.

3. **Evaluate Event Salience Pre-Filtering to Address Multi-Event Rank Shifts:** Because multi-event contextual views exhibited worse anchor retrieval ranks nearly 3x more often than better ranks (`21.58%` [`60/278`] worse vs. `7.55%` [`21/278`] better on TEST; `21.96%` [`65/296`] vs. `7.77%` [`23/296`] on TEST+DEV), consistent with a context-dilution hypothesis, SOC pipelines should evaluate per-event scoring or salience pre-filtering prior to vector encoding.

CHAPTER 5
DISCUSSION

5.1. Research Objectives Revisited

This study set out to resolve a critical empirical question in AI-assisted Security Operations: *When every confounding variable—requested language model alias (`gpt-5.6-luna`), reasoning settings (`reasoning_effort=xhigh`, `max_output_tokens=8192`), prompt wording (`prompts/baseline_v1.txt`), and knowledge base snapshot (MITRE ATT&CK Enterprise v19.2, 474 active Windows techniques)—is held strictly constant, does grounding the model in retrieved ATT&CK reference documents significantly improve exact technique and sub-technique attribution from Windows endpoint logs over unaugmented zero-shot reasoning (RQ1), how do upstream retrieval misses versus downstream selection discrepancies co-occur with end-to-end errors (RQ2), and what are the operational trade-offs across retrieval depths* $k \in \{1, 3, 5, 10\}$ *(RQ3)?*

By executing 6,400 controlled inference requests across the leakage-scrubbed `synthetic-paired-v1` benchmark under Frozen Protocol v1.1 (`D1–D7`), this thesis answered all three Research Questions with full statistical and cryptographic auditability, demonstrating that scientific value in empirical cybersecurity research rests on rigorous hypothesis testing and failure decomposition rather than claiming an artificial 'win' for RAG.

5.2. Summary of Key Findings

1. Synthesis of Empirical Findings Across RQ1–RQ3

- **RQ1 (Metric-Specific Statistical Findings Under Strong Parametric Baseline):** `rag_k10` achieved the highest point accuracy (`79.53%`, 474-class Macro-F1 `0.014024`) over `no_rag` (`77.99%`, Macro-F1 `0.012608`), while `rag_k1` dipped slightly in accuracy to `77.02%` (-0.975 pp). At k=10, the accuracy difference (+1.532 pp, 95% cluster-bootstrap CI [-2.355 pp, +5.300 pp], unclustered exact McNemar $p = 0.4219$) was not statistically significant, whereas the 474-class Macro-F1 difference was +0.001415 with a 95% cluster-bootstrap CI of [+0.001011, +0.001792] (and likewise excluded zero at k=3 and k=5).
- **RQ2 (Upstream Retrieval Miss Co-occurrence & Hit@k vs. Recall@k):** On the 718 scorable TEST views, standalone dense retrieval achieved Hit@10 = 44.71% (`321/718`) and multi-label Macro Recall@10 = 42.80%, missing all ground-truth techniques in **55.29% (397/718)** of views. Accuracy in the retrieved stratum was **91.28% (293/321)** versus **70.03% (278/397)** in the missed stratum, with **80.95% (119/147)** of `rag_k10` classification errors co-occurring with retrieval misses.
- **RQ3 (Token Volume, Cost Reconciliation, and Operational Reliability):** Input token volume grew **7.58x** from `no_rag` to `rag_k10`, while tariff-derived token-usage and ledger cost across all 1,280 logical requests/condition grew **4.60x** from `$0.4671` (`$0.000365`/query) to `$2.1494` (`$0.001679`/query; with `rag_k3` at `$1.1789` and `rag_k5` at `$1.4831`); `rag_k1` recorded

$0.7578 pre-credit usage cost ($0.7575 net of $0.00035420 cache credit) and $1.2972 in conservative ledger spend due to one retained $0.5397 worst-case hold on view_d870d574. Median latency remained stable (2.30s to 2.87s; earlier DEV pilot mean latency of 8.13s across 20 calibration requests is distinguished as an exploratory artifact). Total study conservative ledger spend was **USD 6.5758** (**USD 6.6284** total committed) within the **USD 19.99** ceiling, with 0% provider or parse failures in the 718 scorable cohort.

2. Synthetic Data Boundaries, Ground-Truth Governance, and Runtime Infrastructure Disclosure

Synthetic Data Boundaries & Public Telemetry Governance: While synthetic-paired-v1 isolates retrieval mechanics cleanly, synthetic templates lack the extreme background noise, custom administrative scripts, and adversarial obfuscation of live enterprise networks. Furthermore, our Task 2 forensic discovery of 15,713 cell discrepancies in the Mendeley v3 Windows-APT dataset [13] underscores a broader lesson for cybersecurity machine learning: public telemetry benchmarks must never be ingested without cell-level reconciliation and cryptographic provenance verification.

Runtime Launcher & Infrastructure Resilience Disclosure: To ensure full engineering transparency, we disclose all runtime harnesses used during execution: (1) the authenticated live execution launcher verified against SHA-256 05b60f050cb456688ed74bddb72f994f3b61a84b56f8e568dda4c17467c4c7aa; (2) a Windows atomic file-locking resilience wrapper (12 retries with deterministic exponential backoff delay = 0.05 * (1.5 ** attempt)) mitigating transient WindowsError 5 / 32 exceptions during sequential ledger writes; (3) the scripts/run_offline_tests.py socket-monkeypatch OFFLINE_GUARD verifying zero external network egress during replay; and (4) the sequential runner src/experiment/runner.py (concurrency = 1).

3. Threats to Validity

- **Internal Validity, Bitwise Determinism & Model Provenance (Decision D3):** Mitigated via strict field whitelisting (INFERENCE_ALLOWLIST), byte-identical prompts, and deterministic FAISS tie-breaking. Bitwise determinism holds 100% for dataset regeneration, FAISS indexing, and discrete evaluation counts; across repeated 1,000-resample bootstrap runs (seed=42), all integer counts are invariant, arithmetic invariants hold within $< 10^{-12}$, and the 4 Macro-CI endpoints exhibit floating-point variation $< 6 \times 10^{-18}$. Regarding API provenance (run_provenance.json), the requested model alias (gpt-5.6-luna) and inference configuration were fixed across conditions and timestamped response IDs (has_response_ids: true, has_timestamps: true) were retained; however, an immutable backend model version (model_version: null) and system fingerprints (system_fingerprints: []) were not provided by the upstream API under policy ALLOW_LATEST_WITH_TIMESTAMP_BINDING.

- **Statistical Validity, Cluster Dependence & Multiple Comparisons:** Exact McNemar tests at N=718 (and N=278) treat view-level discordant pairs as independent binary trials without cluster adjustment and are reported unadjusted for multiple comparisons across $k \in \{1, 3, 5, 10\}$. Accordingly, nominal 95% cluster-bootstrap CIs over the 440 scenario clusters (`cluster_unit: pair_id`, `NO_MULTIPLE_COMPARISON_CORRECTION_PRE_SPECIFIED_PRIMARY_CONTRASTS`, treating between-pair independence across template-derived synthetic pairs as a modeling assumption) serve as the primary cluster-aware statistical reference for both Accuracy and 474-class Macro-F1.
- **External Validity & Sparse Class Census:** Positive ground truth in TEST covers 8 active Windows techniques (768 annotations across 718 views), leaving 466 classes in the 474-technique universe with zero support. Generalization to the remaining 466 techniques, other LLM families, or production SOC telemetry cannot be claimed without empirical validation.
- **Construct Validity & Scenario Label Shift:** Multi-label `ANY_MATCH` scoring (D2a) is supplemented by separate single-GT (N=678) and multi-GT (N=40) accuracy reporting, as well as separate sample-level Hit@k and fractional Macro Recall@k metrics. Moreover, as shown in Section 4.3, the 40 label-divergent multi-stage pairs confound direct attribution of single-vs-contextual differences to context windowing alone.

CHAPTER 6
CONCLUSION AND FUTURE WORK

6.1. Conclusion

This Capstone Project Thesis presented **RAG2ATT&CK**, a controlled replication-and-extension empirical study evaluating MITRE ATT&CK-grounded Retrieval-Augmented Generation for exact technique and sub-technique attribution from Windows endpoint telemetry under Scientific Protocol v1.1. Across 6,400 canonical live dispatches (`718` scorable TEST views) using the fixed `gpt-5.6-luna` model alias (`reasoning_effort=xhigh`), `all-MiniLM-L6-v2`, and a FAISS `IndexFlatIP` index over 474 active Windows techniques from MITRE ATT&CK Enterprise v19.2, our study establishes three primary conclusions:

1. **Attribution Efficacy Across Accuracy and 474-Class Macro-F1 (RQ1):** At k=10, RAG achieved the highest point accuracy (`79.53%` vs. `77.99%` for unaugmented `no_rag`, ΔAcc = +1.532 pp, 95% cluster-bootstrap CI [-2.355 pp, +5.300 pp], unclustered exact McNemar p = 0.4219), indicating that the accuracy difference was not statistically significant. Concurrently, the 474-class Macro-F1 difference at k=10 was +0.001415 (`0.014024` vs. `0.012608`), with a 95% cluster-bootstrap CI of [+0.001011, +0.001792] (and positive CIs excluding zero at k=3 and k=5), interpreted under our multiple-comparison disclosure and the sparse 8-of-474 class-support ceiling.
2. **Retrieval Miss Co-occurrence as the Dominant Bottleneck (RQ2):** On the 718 scorable TEST views, standalone dense retrieval achieved sample-level Hit@10 = 44.71% (`321/718`) and multi-label Macro Recall@10 = 42.80%, failing to retrieve any ground-truth technique in **55.29% (397/718)** of views (including a **0.00% Hit@10** blind spot on `T1136.001` across all 95 TEST views). Accuracy in the retrieved stratum reached **91.28% (293/321)** versus **70.03% (278/397)** in the missed stratum, with **80.95% (119/147)** of `rag_k10` classification errors co-occurring with retrieval misses.
3. **Representation Confounding, Cost Accountability, and Zero-Cost Reproducibility (RQ3):** Multi-event contextual views exhibited worse anchor retrieval ranks in **21.58% (`60/278`)** of complete scorable TEST pairs versus **7.55% (`21/278`)** improved (**21.96%, `65/296`** vs. **7.77%, `23/296`** in the combined TEST+DEV T20 cohort), while 80%–100% of net end-to-end contextual wins in `no_rag` and `rag_k1` occurred in 40 multi-stage label-divergent pairs. Operationally, input tokens scaled 7.58x and cost scaled 4.60x at k=10, with the full campaign completing at a conservative ledger spend of **USD 6.5758** (**USD 6.6284** total committed) under the **USD 19.99** guard, permanently archived in GitHub Release `v1.0.0-rag2attck-study` (`ca8d39824a72e80053371e208506bfdc6332dc5d`) for offline reproduction at USD 0.00 API cost.

6.2. Future Work

Building directly upon the observational diagnostics and bottlenecks identified in this thesis, we formulate four concrete hypotheses for future experimental validation:

1. **Hybrid Lexical-Dense Retrieval and Schema-Aware Query Expansion:** Evaluate whether combining sparse lexical matching (BM25 over Windows Event IDs, registry paths, and LOLBin command flags) with dense embeddings via Reciprocal Rank Fusion (RRF) and cross-encoder reranking—augmented by a schema translation layer mapping Windows Security Event ID `4720` attributes (`TimeCreated`, `Computer`, `EventID`, `TargetUserName`, `SubjectUserName`, `SubjectLogonId`) and local-account CLI patterns to canonical ATT&CK concepts (`T1136.001`)—improves recall on zero-hit techniques.
2. **Automated Event Pre-Filtering to Test the Context-Dilution Hypothesis:** Test experimentally whether an upstream event salience filter or per-event max-pooling aggregator before vector encoding improves multi-event retrieval ranks compared to single-vector window pooling.
3. **Verified Real-World Windows Enterprise Telemetry Benchmarking (Task T15 Follow-Up):** Construct and cryptographically seal a real-world Windows intrusion telemetry benchmark collected directly from live Caldera / Atomic Red Team range executions with raw EVTX/JSON provenance hashes, overcoming the 15,713 CSV export discrepancies discovered in Mendeley v3 [13].
4. **Expanded Taxonomic Coverage and Multi-Model Cost-Tiered Routing:** Expand positive benchmark support from 8 techniques to 50+ Windows techniques across the 474-technique matrix, and evaluate a tiered SOC routing architecture pairing fast open-weight models (`Llama-3.3-70B`, `Qwen-3`) on high-confidence hits with frontier reasoning models (`gpt-5.6-luna`) reserved for ambiguous escalations.

REFERENCES

[1] The MITRE Corporation. "MITRE ATT&CK® Enterprise Matrix, Version 19.2." Published 05 August 2026. Available: https://github.com/mitre-attack/attack-stix-data/releases/tag/v19.2 (version history: https://attack.mitre.org/resources/versions/).

[2] OpenAI. "GPT-5.6 Luna Model." OpenAI API Documentation, accessed 02 October 2026. Available: https://developers.openai.com/api/docs/models/gpt-5.6-luna.

[3] OpenAI. "Reasoning Models." OpenAI API Documentation Guides, accessed 02 October 2026. Available: https://developers.openai.com/api/docs/guides/reasoning.

[4] Lewis, P.; Perez, E.; Piktus, A.; Petroni, F.; Karpukhin, V.; Goyal, N.; Küttler, H.; Lewis, M.; Yih, W.-t.; Rocktäschel, T.; Riedel, S.; Kiela, D. "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks." In: *Advances in Neural Information Processing Systems (NeurIPS 2020)*, vol. 33, pp. 9459–9474, 2020.

[5] Lekssays, A.; Shukla, U.; Sencar, H. T.; Parvez, M. R. "TechniqueRAG: Retrieval Augmented Generation for Adversarial Technique Annotation in Cyber Threat Intelligence Text." In: *Findings of the Association for Computational Linguistics: ACL 2025*, pp. 20913–20926, 2025. DOI: https://doi.org/10.18653/v1/2025.findings-acl.1076; arXiv: https://arxiv.org/abs/2505.11988.

[6] Morbiato, F.; Keller, M.; Nair, P.; Romano, L. "Hierarchical Retrieval Augmented Generation for Adversarial Technique Annotation in Cyber Threat Intelligence Text." *arXiv preprint* arXiv:2604.14166, 2026. Available: https://arxiv.org/abs/2604.14166.

[7] Yang, D.-R.; Hsu, F.-H. "LLM-Based Malicious Behavior Detection from Sysmon Event Logs: A Practical System Integrating Process Trees, RAG, and In-Context Analysis." In: *Security and Information Technologies with AI, Internet Computing and Big-Data Applications (SITAIBA 2025)*, Smart Innovation, Systems and Technologies, vol. 8767, pp. 235–251, Springer Cham, 2026. DOI: https://doi.org/10.1007/978-3-032-24063-7_18.

[8] Landauer, M.; Hotwagner, W.; Boenke, T.; Skopik, F.; Wurzenberger, M. "CAM-LDS: cyber attack manifestations for automatic interpretation of system logs and security alerts." *International Journal of Information Security*, vol. 25, art. 148, 2026. DOI: https://doi.org/10.1007/s10207-026-01318-x; arXiv: https://arxiv.org/abs/2603.04186.

[9] Okuma, M.; Watarai, K.; Okada, S.; Mitsunaga, T. "Automated Mapping Method for Sysmon Logs to ATT&CK Techniques by Leveraging Atomic Red Team." In: *2023 6th International Conference on Signal Processing and Information Security (ICSPIS 2023)*, pp. 104–109, IEEE, 2023. DOI: https://doi.org/10.1109/ICSPIS60075.2023.10343783.

[10] Adediran, G.; Awuson-David, K.; Ahmed, Y. "Retrieval-Augmented Large Language Model for AWS Cloud Threat Detection and Modelling: Cloudtrail Mitre ATT&CK Mapping." *Computers, Materials & Continua*, vol. 87, no. 2, art. 100, 2026. DOI: https://doi.org/10.32604/cmc.2026.077606.

[11] Lupinacci, M.; Arena, L.; Blefari, F.; Furfaro, A. "A Graph-Based Approach for Mapping Kernel-Level Telemetry to MITRE ATT&CK." *arXiv preprint* arXiv:2609.12841, 2026. Available: https://arxiv.org/abs/2609.12841.

[12] Gwak, J.-Y.; Strier, A.; Xi, Z.; Yan, G.; Shu, X.; Stoller, S. D.; Yang, P. "LADE: LLM-Assisted Advanced Persistent Threat Detection and Explanation." In: *Security and Privacy in Communication Networks (SecureComm 2026)*, Lecture Notes of the Institute for Computer Sciences, Social Informatics and Telecommunications Engineering, vol. 705, pp. 245–273, Springer Cham, 2026. DOI: https://doi.org/10.1007/978-3-032-32767-3_11; Available: https://www3.cs.stonybrook.edu/~stoller/papers/LADE-2026.pdf.

[13] Mozaffari, M.; Yazdinejad, A.; Dehghantanha, A. "Windows-APT 2025: A dataset for APT-inspired attack scenarios on windows systems." *Data in Brief*, vol. 65, art. 112569, 2026. DOI: https://doi.org/10.1016/j.dib.2026.112569; Mendeley Data v3: https://doi.org/10.17632/b8fmtzvpy8.3.

APPENDICES

Appendix A: Cryptographic Reproducibility Manifest and Certified Execution Lineage

In adherence to open-science principles, all code, configurations, corpora, and execution artifacts of the RAG2ATT&CK study (`https://github.com/habachcp6/RAG2ATTCK`, Release `v1.0.0-rag2attck-study`) are bound to immutable SHA-256 digests in Table 11 and Table 12.

Table 11: Cryptographic Reproducibility Manifest.

Asset Description	File Path	Digest Type	Canonical SHA-256 Digest
Scientific Protocol Decisions Digest	`config/experiment_protocol_v1.json`	Protocol Digest	`d3bf3d31ad307100ac437a7daecc470bf12de9ada49f19de3d77592d5a21974c`
Protocol Configuration File	`config/experiment_protocol_v1.json`	File SHA-256	`a402b04ab463172f9d4079bff27b089ca8a21ffd0805d097af6cb1f3c7b5a8fb`
Model Configuration File	`config/model.json`	File SHA-256	`312c34cedd84106f2004c6070b72aeac1dd84209a464e2993fee3ec87822697f`
Retrieval Configuration File	`config/retrieval.json`	File SHA-256	`b33a93913e7f6de36f6f9021f77b2c9dcb1d426929162acb250a3c73ac8e6e25`
Benchmark Scope File	`config/benchmark_scope.json`	File SHA-256	`d6aa89831dec75362b4fd48de0fd6e7082290f2be0cb7bd0afc6bc518148db8b`
Base Prompt Template File	`prompts/baseline_v1.txt`	File SHA-256	`b751fde1ee33b03ec0bdc07cbba10267002d2086cf22b91a74bdfd123856f206`
ATT&CK Enterprise v19.2 Raw STIX	`attack/raw/enterprise-v19.2/enterprise-attack-19.2.json`	File SHA-256	`dc1639caa5501d720e280cf1cbd8fbe009884a0c9b3e6e9ed9d0c25166c3d8f4`
Active Windows Retrieval Corpus	`attack/corpus/enterprise-windows-v19.2.jsonl`	File SHA-256	`b219341154ddf2f12e97d622158a04ab7d57641df6a865559258d365852c3c75`
Corpus Manifest File	`attack/corpus/enterprise-windows-v19.2.manifest.json`	File SHA-256	`6bd769324f6ac9193d7df82e7f54f5a1397a41b9bc72be767da5a72b54b3a47c`
FAISS Binary Index File	`attack/index/enterprise-windows-v19.2.index`	File SHA-256	`7e3b9944870860766ebd5ba76f19a420c1bbe57cebd4e4238b06fd31128578e5`
Index Document Mapping File	`attack/index/enterprise-windows-v19.2.docmap.json`	File SHA-256	`a7de3dfcf2b6e186e639d2922fcbc27766c160ae58bbafea74b5efc0faf30586`
Dataset Manifest File	`data/ground_truth/synthetic/dataset_manifest.json`	File SHA-256	`4576b793360d02b60d619d199fd34d4555ace33215303ee847715c162a50dcc2`
Live Execution Launcher Hash	Runtime wrapper entrypoint	Code SHA-256	`05b60f050cb456688ed74bddb72f994f3b61a84b56f8e568dda4c17467c4c7aa`

Table 12: Supplementary Execution Provenance (Canonical Run Mode).

Asset Description	File Path / Identifier	Digest Type	Hash / Git SHA
Canonical Metric Bundle	`artifacts/results/canonical_metric_bundle_v2.json`	File SHA-256	`442b5933858caafc9da3c06ee9398637213ed30d7a7db80195c0babb1195ef34`

Asset Description	File Path / Identifier	Digest Type	Hash / Git SHA
Canonical Overall Metrics	`artifacts/results/outputs/overall_metrics.json`	File SHA-256	`25662753963ecdd05d16b8607095fffb964c0d53cd2c43026c50b47b22e55074`
Canonical Condition Metrics	`artifacts/results/outputs/per_condition_metrics.json`	File SHA-256	`e6592f9a0f97739be1168f9d1448e0d209fe4a300727ff6ad78902523f1591d6`
Canonical Retrieval Conditional	`artifacts/results/outputs/retrieval_conditional_metrics.json`	File SHA-256	`2c68395f4ae923167b7cbc08835ff2772044ddc7695f69c0781ec277287d775f`
Canonical RQ Analysis	`artifacts/results/outputs/rq_analysis.json`	File SHA-256	`1604a5537b57cefbe86fd59d7fa2acfb8658a27215f7df8a98dfd0c400981156`
Canonical Run Provenance	`artifacts/results/outputs/run_provenance.json`	File SHA-256	`90918c9efe149c537c9b2cee7f7392607f273c12627bcc61b9dc9443359e63a1`
Terminal Snapshot Seal	`reports/evidence/canonical_run_seal_v1.json`	File SHA-256	`ae7a9ada86927a79e0c6916b44d3f0ba9e1f9756df55dd7b2fce712b35d48701`
Execution Commit	Runner execution state	Git Commit SHA	`80dbeb3fe2316e5d2d39de2ed6a5a2d15cfa9315`
Official Release Merge Commit	Tag `v1.0.0-rag2attck-study` (ID `402490699`)	Git Commit SHA	`ca8d39824a72e80053371e208506bfdc6332dc5d`
Documentation Sync Commit	Branch `main` after PR #39	Git Commit SHA	`84b6e5071d063bd4471cc70d477458855ac9c3ea`

Independent auditors can reproduce all headline metrics, 1,000-resample cluster-bootstrap CIs, exact McNemar tests, and financial reconciliations offline at USD 0.00 API cost from `public_v4_candidate_20261003.zip` (SHA-256: `1d5f9f4bb2d50bbb885746fe4d26f34ca5af1cacdbcad7e0005c2af8ea1086c1`) using:

```
python scripts/run_offline_tests.py -m scripts.reproduce_canonical_study \
  --bundle-dir <package-root> \
  --repository-root <checkout> \
  --output-dir <new-output-dir> \
  --all
```

Appendix B: Eight-Week Capstone Implementation Roadmap (Planned vs. Actual Execution) and Risk Register

Synchronized with the official Google Drive Project Tracker (`RAG_ATTCK_Project_Tracker_Updated`, 35/35 in-scope tasks completed, 1 task `T15` deferred out-of-scope per Protocol v1.1 Decision D6) and Research Plan (`RAG_ATTCK_Research_Plan_Updated`, Section 15 Scope Alignment Addendum), Table 13 explicitly distinguishes the **8-week syllabus planned schedule windows** (`W1–W8`, `15 Sep–9 Nov 2026`) from the **actual execution timestamps** (`run_provenance.json 2026-10-02T03:43:44Z`, evaluation bundle freeze `03 Oct 2026`, and documentation/release freeze `19–30 Oct 2026`, completed ahead of the planned `W5–W8` windows). Table 14 documents the project risk register and implemented reproducibility controls.

Table 13: Eight-Week Capstone Implementation Roadmap: Planned Window vs. Actual Execution Timestamps.

Phase	Planned Schedule Window	Task IDs	Core Deliverable & Acceptance Criteria	Actual Completion Date & Audit Evidence	Status
Literature & Scope	W1 (15–21 Sep 2026)	T01–T04	Freeze replication-and-extension framing, annotate 8 core comparators, finalize RQ1–RQ3, and freeze 16-dimension comparator matrix.	21 Sep 2026 (`reports/T33_related_work.md`, PR #8)	Done (4/4)
Data & Ground Truth	W2 (22–28 Sep 2026)	T05–T10	Audit Mendeley v3 telemetry (15,713 discrepancies stopped at Task 2), engineer `synthetic-paired-v1` (670 pairs / 1,340 views), and pass `INFERENCE_ALLOWLIST` leakage audit.	28 Sep 2026 (`dataset_manifest.json 4576b793...`)	Done (6/6)
No-RAG Baseline	W3 (29 Sep–5 Oct 2026)	T11–T14	Fix `gpt-5.6-luna` alias (`reasoning_effort=xhigh`), implement OpenAI Responses API client with JSON schema & two-layer validation, and freeze `prompts/baseline_v1.txt`.	30 Sep 2026 (`model.json 312c34ce...`, `baseline_v1.txt b751fde1...`)	Done (4/4)
Real Telemetry Pilot	W3 (29 Sep–5 Oct 2026)	T15	Real Windows telemetry pilot formally deferred per Protocol v1.1 Decision D6 (`NOT_REQUIRED_FOR_SYNTHETIC_BENCHMARK`, `DATA_UNAVAILABLE`).	30 Sep 2026 (Protocol v1.1 Decision D6 freeze)	Deferred / Out-of-Scope (1)
RAG Pipeline	W4 (6–12 Oct 2026)	T16–T20	Pin ATT&CK Enterprise v19.2 (474 active Windows docs), build `all-MiniLM-L6-v2` + FAISS `IndexFlatIP` retriever, and execute T20 retrieval diagnostics.	01 Oct 2026 (`retrieval_metrics.json 3e40e18f...`)	Done (5/5)
Main Experiments	W5 (13–19 Oct 2026)	T21–T26	Freeze Protocol v1.1 (`D1–D7`), enforce USD 19.99 financial guard, and execute 6,400 canonical live dispatches (`live-66b94b1676bf46a9`).	02 Oct 2026 (`run_provenance.json 2026-10-02T03:43:44Z`, ahead of schedule)	Done (6/6)
Evaluation	W6 (20–26 Oct 2026)	T27–T30	Compute end-to-end metrics, 474-class Macro-F1 (D2d/D2j), 95% cluster-bootstrap CIs (440 clusters), McNemar tests, Hit@k vs. Recall@k, and D2i failure axes.	03 Oct 2026 (`canonical_metric_bundle_v2.json 442b5933...`, ahead of schedule)	Done (4/4)

Phase	Planned Schedule Window	Task IDs	Core Deliverable & Acceptance Criteria	Actual Completion Date & Audit Evidence	Status
Report	W7 (27 Oct–2 Nov 2026)	T31–T33	Author Methodology, Experiments & Results, Discussion, and 16-dimension comparator synthesis with 8 high-resolution figures and 14 canonical tables.	19–30 Oct 2026 (Git `84b6e507...`, ahead of schedule)	Done (3/3)
QA & Submission	W8 (3–9 Nov 2026)	T34–T36	Execute offline reproducibility QA (178/178 tests passed), finalize presentation kit, and publish `public_v4_candidate_20261003.zip` & Release `v1.0.0-rag2attck-study`.	20–30 Oct 2026 (Release `ca8d3982...`, completed ahead of W8 window)	Done (3/3; Total 35/35 In-Scope)

Table 14: Risk Register, Severity Assessment, and Reproducibility Mitigation Controls.

Risk Category	Severity	Mitigation Control Implemented in RAG2ATT&CK
Generic RAG-vs-No-RAG novelty overlap	Medium	Framed strictly as a controlled conceptual replication-and-extension study on Windows endpoint logs with exact attribution and failure decomposition; zero unsubstantiated 'first-ever' claims.
Label leakage from detector rules / metadata	High	Enforced `INFERENCE_ALLOWLIST` in `src/synthetic.py` retaining only `sample_id` and sanitized per-channel behavioral `endpoint_evidence` (e.g., `TargetUserName`, `SubjectUserName`, `SubjectLogonId`, `CommandLine`); purged all Sigma/Wazuh rule names, `rule.mitre.*`, and `Contoso` markers.
Corrupted external public telemetry (Mendeley v3)	High	Forensic Task 2 audit detected 15,713 cell discrepancies (`_source.id` truncation, `#NAME?` formulas); enforced fail-closed stop (`RECONCILIATION_DIVERGENT`) and bounded claims strictly to `synthetic-paired-v1` under Protocol D6.
Class support concentration & zero denominators	Medium	Frozen 474-class Macro-F1 universe (`D2d`) combined with explicit `NULL` zero-denominator semantics (`D2j`) and piecewise count formula across all boundary cases; reported support-based upper bound ($8/474 \approx 1.69\%$).
API cost overrun & transient provider errors	Medium	Pre-dispatch worst-case reservation (`$0.53974560`/attempt), 25,600 attempt cap, deterministic exponential backoff (`max_retries=3`), settling at `$6.5758` (`$6.6284` total committed) under `$19.99` ceiling.
Upstream API model version mutability	Low	Fixed requested model alias (`gpt-5.6-luna`) and inference settings across conditions; logged timestamped response IDs (`run_provenance.json`) and disclosed `model_version: null` and `system_fingerprints: []` under Decision D3.
Prompt asymmetry across conditions	Medium	Used byte-identical `prompts/baseline_v1.txt` (`b751fde1...`) with a universal context handling clause across No-RAG and all RAG depths.
Post-publication irreproducibility / API cost barrier	Low	Published portable verification archive `public_v4_candidate_20261003.zip` (`1d5f9f4b...`) and `scripts.reproduce_canonical_study` under `OFFLINE_GUARD` (`$0.00` API cost, $< 10^{-12}$ numeric tolerance).